



Federal Office
for Information Security

Evaluation Guidance

Injection Attacks

Version 0.3 (00111c7, 22.07.2026)



Bundesamt für Sicherheit in der Informationstechnik
PO Box 20 03 63
53133 Bonn
E-Mail: referat-d11@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2026

Document History

Version	Date	Editor	Description
0.1	2025-09-19	D11	Document initialized
0.2	2026-03-30	D11	First internal draft
0.3	2026-07-22	D11	Draft for review

Table .1 Document Revisions

Table of Contents

1	Introduction	1
1.1	Purpose of the Document	1
1.2	Scope	1
1.3	Evaluation Levels	2
1.4	Outline	2
1.5	Open Questions	3
1.6	Terms	3
1.7	Normative Elements	3
2	Prerequisites and Basic Requirements	5
2.1	Obligations on the Part of the Manufacturer	5
3	Overview over the Injection Attack Methods and Instruments	7
3.1	Application Types	7
3.2	Data Processing Architecture	8
3.3	Data Handling	8
3.4	IAI Real-Time Capability	8
3.5	Injection Attack Methods	9
3.6	Injection Attack Instruments	10
4	Pre-Evaluation Phase	12
4.1	Documentation	12
4.2	Initial Functional Test of the IAD System	13
4.3	Pre-Evaluation Process	13
5	Evaluation Phase	19
5.1	General Requirements	19
5.2	Evaluation Metric	19
5.3	Fixed Time Methodology	20
5.4	Minimal Test Coverage	21
5.5	Expected Result of IAD Evaluation	24
5.6	Evaluation Report	24
A	Relevant Requirement Catalogues	25
A.1	BSI TR-03147: Requirement catalogue for identification procedures	25
A.2	ETSI TS 119 461	25
B	Possible Additional IAM	26
B.1	Unverified Injection Attack Methods	26
C	Attack Rating Methodology	27
C.1	Identification and Exploitation Phases	27
C.2	Attack Potential Levels	27
C.3	Interpreting the Ratings	27
C.4	Combining Method and Instrument Ratings	28
C.5	Common Assumptions	28

C.6	Role of Optimization Aspects	28
D	Guidance on Injection Methods	29
D.1	Software-Based Injection Methods	29
D.2	Hardware-Based Injection Methods	33
D.3	Network-Based Injection Methods	34
D.4	Application-Level Injection Methods	35
D.5	Supplementary Optimization Techniques	39
E	Guidance on Injection Instruments	43
E.1	Genuine Attacks	43
E.2	Face Synthesis and Manipulation Techniques	44
E.3	ID Document / Security Feature Synthesis	49
E.4	Adversarial Attacks	54
E.5	Post-Processing of Manipulations	57
	List of Abbreviations	61
	Bibliographie	62

List of Figures

- 1.1. Scope of the document displayed as one attack vector at a specific stage of a biometric comparison process amongst others. 2

1 Introduction

1.1 Purpose of the Document

This document is part of a set of guidelines supporting a standardized evaluation of remote identity proofing (RIDP) systems against the requirements of ▶BSI TR-03147. Other requirement catalogues that address the evaluation of injection attack methods, such as ▶ETSI TS 119 461, may build on this guidance or refer to it. It focuses on the sub-components of the RIDP system that are responsible for detecting injection attack attempts, as well as the components responsible for detecting injected data (cf. Scope in ▶Section 1.2).

This document provides evaluation guidance for testing injection attack detection (IAD) mechanisms in biometric systems, serving as a companion to ▶EG BSI TR-03166, which is an evaluation guidance that covers biometric performance and presentation attacks. Unlike presentation attacks where physical artifacts are presented to sensors, injection attacks bypass the sensor by introducing data directly into the biometric system's data stream in the processing pipeline.

Furthermore, this document aims to provide a foundational baseline of possible injection attack methods (IAMs) and injection attack instruments (IAIs) that represent the state of the art at the latest release of the document. Thereby it aims to support the standards ▶CEN/TS 18099 and ▶ISO/IEC 25456 to establish a catalogue of methods and instruments that should generally be covered in biometric injection attack detection evaluations.

1.2 Scope

This document covers the evaluation of automatic, algorithmic detection capabilities to detect injection attempts trying to cover all publicly known attack vectors. The evaluation quantifies the difficulty of bypassing these automated systems without human intervention. Meaning it excludes cases where an operator guides or observes the tasks a user should perform, as well as human decisions made after a verification process on the collected data. Human observation, either on the process itself or on the recorded data, as an additional security layer can alter the security assessment but is explicitly excluded from this evaluation and must be discussed separately. This document solely focuses on the effectiveness and bypass resistance of the automatic detection system itself.

In the current version, the document focuses on injection attack instruments targeting face biometrics and ID documents. In future iterations and if demand is given, it is intended to extend this also to other modalities, to provide more general evaluation guidance on injection attacks. In most cases, the injection attack methods presented in this document already apply to all modalities.

Since IAD is only one aspect of assessing the RIDP systems overall reliability, this evaluation guidance should be seen as only one part of a series of documents.

Assumptions made in this document are listed in ▶Table 1.1.

[Assumption-1]	The capturing device is under full user control without physical supervision.
[Assumption-2]	The presented data is either a replay/relay of genuine material or other material that was manipulated on the digital level, i.e. no presentation attack.
[Assumption-3]	The performance of the biometric comparison system is confirmed to be in conformance with the targeted level of assurance.
[Assumption-4]	The IAD component is part of the target of evaluation (TOE) itself and not a separate SDK or API called within the TOE.

Table 1.1 Assumptions made in this document, which are necessary for the evaluation

Notes on assumptions:

Assumption 1: This basically assumes that for RIDP the user is generally allowed to perform the process in an environment under the control of the user. The user can potentially modify the device, operating system, application, or network traffic used to communicate with the RIDP service. While client-side security measures may be implemented, they are part of the untrusted client environment and subject to bypass.

To assess the conformance to assumptions 3 and 4, the following documents should also be taken into account:

- Evaluation Guidance of ►BSI TR-03166: ►EG BSI TR-03166
- Evaluation Guidance for Remote Identity Proofing - Part 03: ID documents ►EG BSI ID-Docs

Assumption 4: If the TOE is an SDK or API for IAD that is supposed to be integrated in other applications, the worst case implementation for a specific environment allowed by the SDK has to be evaluated by this evaluation guidance. Then in the best case for any integrating application, only the correct integration, following the SDK instructions, has to be confirmed. However note that separate evaluations may have to be performed for varying operation environments such as desktop, Android or iOS as the SDK may operate differently in those.

Target of Evaluation

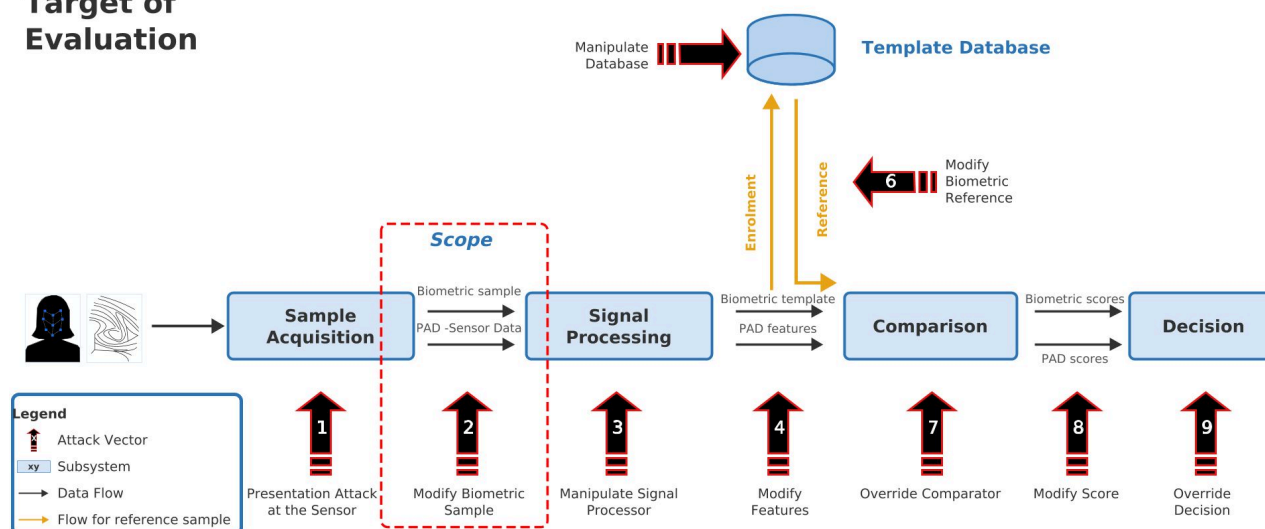


Figure 1.1. Scope of the document displayed as one attack vector at a specific stage of a biometric comparison process amongst others.

►Figure 1.1 displays the scope of this evaluation guidance (attack vector 2) in context of possible attack vectors on RIDP systems. To evaluate the resilience of the system against presentation attacks on the sensor (attack vector 1), refer to ►BSI TR-03166 when considering the module face and ►EG BSI ID-Docs for ID documents.

1.3 Evaluation Levels

This document states procedures to evaluate an IAD system with varied evaluation levels. The evaluation-levels are defined such that they are in conformance with the requirements of ►BSI TR-03147 that are relevant to injection attacks. Fulfilling the requirements of ►BSI TR-03147 results in reaching the assurance levels defined in ►BSI TR-03107, which in turn are designed such that the minimal requirements of the eIDAS level of assurance (LoA) are fulfilled (refer to ►BSI TR-03147). ►Table 1.2 shows the mapping between the different levels and the resistance to potential attack levels.

Resistance against Attack Potential	Evaluation Level / Assurance Level BSI TR-03107	Level of Assurance (LoA) eIDAS
Enhanced-Basic	normal	LoA low
Moderate	substantial	LoA substantial
High	high	LoA high

Table 1.2 Mapping between evaluation levels, assurance levels and eIDAS level of assurance.

1.4 Outline

In ►Chapter 2 the prerequisites and basic requirements for the performance of the evaluation are described, outlining what the manufacturer has to provide such that the testing laboratory can perform the evaluation. In ►Chapter 3 an overview of IAMs and IAs covered as a baseline of this evaluation is given, as well as a guidance on how to determine their relevance for a given TOE. In ►Chapter 4 the initial pre-evaluation on a test system is discussed. In ►Chapter 5 the full system evaluation is described. ►Appendix A describes the relevance of this evaluation to the respective requirements of ►BSI TR-03147 and ►ETSI TS 119 461. ►Appendix B describes additional IAMs that are known but out of scope of the current version of the evaluation

guidance. ►Appendix C describes the attack rating methodology used in this evaluation guidance to estimate the attack potential of a IAM and IAI combination in alignment with ►CEN/TS 18099. Finally, ►Appendix D and ►Appendix E give detailed guidance on the identification, exploitation and optimization of the discussed IAMs and IAIs. The two appendices are intended to represent the current state of the art of attack methods and instruments, and are therefore expected to be considered as a baseline in any security evaluation.

1.5 Open Questions

Some questions in the evaluation of IAD systems are still open and not properly addressed by this guidance yet. It is intended to resolve them in future versions of this document.

- Use of cloud-based tools during the evaluation, considering that testing laboratories may be required to upload their own identity data, e.g. to generate deepfakes with the tool. A data processing agreement would be necessary between the testing laboratory and the cloud service provider and question remains if guidance on this should be part of this document. However, on-premises solutions exist for all the mandatory tests described in this document, which reduces the urgency of this issue.
- Whether tools should be provided to testing laboratories, and the associated liability considerations. In particular, if an evaluation fails to demonstrate that a generally feasible attack scenario is successfully mitigated by the TOE, due to implementation errors in the provided tools rather than the actual resilience of the system, the question of liability must be addressed.
- Proper coverage of iOS-specific injection attacks. Currently most attacks on mobile applications focus on attacks that leverage the Android environment. In future after proper assessment, iOS specific attacks should also be included in the evaluation schemes.

1.6 Terms

In ►Table 1.3 terms used throughout this document are described for a common understanding. The terms are set to be in alignment with ►BSI TR-03166, ►CEN/TS 18212-5 and ►CEN/TS 18099.

Term	Descriptions
bona fide	subject that interacts with the TOE with a legitimate use and without any intention to attack it
injection attack (IA)	action of interfering with the biometric system by replacing the original data sample captured by the data capture subsystem before the execution of the feature extraction process
injection attack instrument (IAI)	biometric sample, which may be a modified biometric sample, used in a biometric data injection attack
injection attack method (IAM)	method to alter the output of a biometric data capture subsystem
injection attack detection (IAD)	automated detection of a biometric data injection attack
remote identity proofing (RIDP)	a system that remotely validates that an authentic user is physically present in front of the capturing device and in possession of a genuine and valid ID document, issued by an authoritative source, matching to his identity
target of evaluation (TOE)	set of software, firmware and/or hardware possibly accompanied by guidance, which is the subject of an evaluation

Table 1.3 List of terms used throughout this document and their descriptions.

1.7 Normative Elements

This document uses the modal verbs defined in ►Table 1.4 to differentiate the extent to which requirements are compulsory.

Modal verb	Description
SHALL	This word means that the implementation is an absolute requirement.
SHALL NOT	This phrase means that the implementation is an absolute prohibition.

Modal verb	Description
SHOULD	This word means that the implementation is an absolute requirement unless it is demonstrated that there is no risk to secure operation by not implementing it, or implementation, due to technical limitations, is not currently feasible.
SHOULD NOT	This phrase means that the implementation is an absolute prohibition unless it is demonstrated that there is no risk to secure operation by implementing it, or, due to technical limitations, prevention of the prohibited practice is not currently feasible.
MAY	This word means that the implementation is optional.

Table 1.4 Modal verbs and their meaning in this document.

2 Prerequisites and Basic Requirements

This section specifies prerequisites that have to be fulfilled before any evaluation by a testing laboratory can start. This includes especially requirements on the part of the manufacturer that have to be provided. In the case, where an evaluation targets the level *substantial* or higher, a test system has to be provided by the manufacturer to the testing laboratory, so the evaluators can perform a robust vulnerability analysis with high confidence in a reasonable amount of time with limited budget. The requirements on this test system are also listed within this section.

2.1 Obligations on the Part of the Manufacturer

2.1.1 Target of Evaluation

The following requirements outline the aspects that have to be covered by the manufacturer and must be provided before the start of any evaluation.

Nr.	Requirement
[REQ-TOE-01]	The manufacturer SHALL document all elements that are part of the TOE and specify any changeable configuration and versioning. The manufacturer SHALL define the parameter space for changeable configurations and the evaluator SHALL be allowed to configure those during testing.
[REQ-TOE-02]	The manufacturer SHALL define the context and intended use of the IAD system, including how the full system is intended to be used in production.
[REQ-TOE-03]	The manufacturer SHALL define the targeted evaluation level.
[REQ-TOE-04]	The manufacturer SHALL define tests that were performed by the manufacturer and how they were evaluated.
[REQ-TOE-05]	The manufacturer SHALL give an introduction of the TOE and its usage to the evaluators and the processes to be performed prior to the evaluation.
[REQ-TOE-06]	For evaluations targeting evaluation level <i>substantial</i> or higher, the manufacturer SHALL provide detailed documentation of all security-relevant components of the TOE, including a functional description of each component, its role in the IAD decision process, and its interaction with other components.
[REQ-TOE-06a]	This documentation SHALL include the architecture of any machine learning models used within the IAD system, where applicable.
[REQ-TOE-06b]	This documentation SHALL include details on public datasets used for training machine learning models used within the IAD system, where applicable.
[REQ-TOE-06c]	This documentation SHALL include details on non-public datasets used for training machine learning models used within the IAD system, where applicable.
[REQ-TOE-07]	For evaluations targeting evaluation level <i>substantial</i> or higher, the manufacturer SHALL disclose the implementation of all IAD-relevant components of the TOE to the evaluator.

Table 2.1 Requirements for the specification of the target of evaluation.

Note to ►REQ-TOE-01: The testing laboratory should test the worst case configuration that is allowed by the system.

2.1.2 Test System

Where an evaluation is performed that targets evaluation levels *substantial* or higher, the testing laboratory must be provided with a test system. The test system is intended to be a gray box replication of the actual TOE and used in the pre-evaluation phase such that the testing laboratory can determine and optimize all relevant injection attack methods and instruments. The necessity for this test system lies in the difficulty of properly determining whether the sample of moderate and high attack potential injection attacks sufficiently cover all potential vulnerabilities, or whether minor adjustments to the sample set could make the difference between an ineffective and a successful attack. To increase the confidence in the evaluation results while keeping the evaluation time within a reasonable amount, the test system bridges the gap for the high attack potentials. It is intended to be used in a pre-evaluation phase, where potential vulnerabilities can be assessed and attacks

refined by the testing laboratory. The actual evaluation shall then be performed on a system that is equivalent to the productive system.

Nr.	Requirement
[REQ-TST-01]	For evaluations targeting evaluation level <i>substantial</i> or higher, the manufacturer SHALL provide the testing laboratory with a test system with controlled testing interface (evaluation mode) that exposes all internal metrics, scores, and decision logic contributing to the final accept/reject decision of the system. This includes, but is not limited to, individual subsystem scores, confidence values, threshold configurations, and the aggregation logic used to derive the final decision.
[REQ-TST-02]	For evaluations targeting evaluation level <i>high</i> , the evaluation mode SHALL additionally allow the laboratory to evaluate individual security-relevant sub-components of the TOE separately and, where feasible, with controlled isolation or selective activation/deactivation of components under diagnostic conditions.
[REQ-TST-03]	For evaluations targeting evaluation level <i>substantial</i> or higher, the manufacturer SHALL demonstrate that the test system (apart from modifications explicitly made to enable the evaluation mode, cf. ▶REQ-TST-01 & ▶REQ-TST-02) is equivalent to the productive system with respect to all security-relevant components of the TOE. Where this is not possible refer to ▶REQ-TST-04.
[REQ-TST-04]	For evaluations targeting evaluation level <i>substantial</i> or higher, any deviation between test and productive system SHALL be documented and justified by the manufacturer.
[REQ-TST-05]	For evaluations targeting evaluation level <i>substantial</i> or higher, the manufacturer SHALL grant the evaluator access to the test system to the extent that it is necessary for the evaluation of the TOE, including an unrestricted number of tests.
[REQ-TST-06]	For evaluations targeting evaluation level <i>substantial</i> or higher, the manufacturer SHALL ensure that biometric data and injected videos used during testing do not leave the test system and are deleted on demand of the evaluator.

Table 2.2 Requirements on the test system for evaluation level *substantial* or higher.

Note to ▶REQ-TST-01: to reduce friction and truly help assessing the security of the system, any metrics that contribute to the final decision of IAD shall be provided to the evaluator. These metrics should be suited to assist the evaluator in assessing the effectiveness of an attack against each individual subsystem. This way the evaluator can determine whether tested attacks are truly detected and minor modifications in the attack would not result in a breach. Additionally, the capabilities of detecting attacks by highly capable attackers can be evaluated by not requiring as much time and skill from the evaluators, making it feasible to also assess highly skilled and dedicated attackers within reasonable time and effort.

Note to ▶REQ-TST-02: Subsystems (e.g., root detection, deepfake detection, face comparison, and face quality estimation) should be deactivatable by the evaluator for evaluation levels that target *high*. This enables the isolated assessment of individual components in the pre-evaluation and helps to determine their specific contribution to the overall security of the TOE.

3 Overview over the Injection Attack Methods and Instruments

This section gives an overview over the possible IAMs and which IAs are relevant for the evaluation. To determine which IAMs and IAs are relevant for a given TOE, the evaluator should consider the application type (►Section 3.1), the data processing architecture (►Section 3.2), and the data handling (►Section 3.3), which specifies whether data is processed as a live stream or persisted as files before processing. Furthermore, the capability of the respective IAI (►Section 3.4) to operate in real-time or only with pre-rendered material must be taken into account to determine the set of feasible IAMs and IAs.

3.1 Application Types

The architecture and operation environment of the RIDP systems strongly influences which IAMs can be feasible and effective. To determine which IAMs are relevant, in this guideline applications are categorized by their platform type. If a RIDP service provider offers its service through multiple application types, each must be evaluated separately for injection attacks due to the different nature of available IAMs for each platform.

3.1.1 Desktop Application

Desktop applications are standalone installable applications (e.g. for Windows, Linux or macOS). They are typically distributed via direct download or application stores and installed on the user's system. Once installed, they have direct access to OS APIs and can query hardware information. Users are generally free to interchange external devices (i.e. webcams) used in the process and are therefore able to attempt attacks with the lowest resolution and hardware feature capabilities allowed by the application. Furthermore, users operating their own hardware in unsupervised settings typically have superuser permissions on the system, which enables more powerful attacks to spoof OS behavior and inject manipulated video streams.

3.1.2 Mobile Application

Mobile applications are native or cross-platform applications for mobile operating systems (typically Android or iOS). They are primarily distributed through official app stores (i.e. Google Play Store, Apple App Store) and operate within the mobile OS security sandbox. Camera access is mediated through the OS permission system, and hardware-backed security features (TEE, Secure Enclave) may be available to the application. For a specific mobile device, the camera and its capabilities are typically fixed and consistency checks can be performed by the application to determine whether recorded data fits with the reported device. The main platforms for mobile application (Android or iOS) provide platform or software attestation mechanisms. However, their effectiveness and robustness are usually not proven (e.g. by a certification process) and they are not known to cover components such as the camera. Typically, mobile devices contain additional sensors (e.g. accelerometer, gyroscope, magnetometer, etc.) that can be checked by the application for consistency. Some mobile phones contain sensors such as infrared cameras that are missing in most other mobile devices. They can provide valuable additional data for the evaluation but requiring them for the application may come with a reduced user base. Injection attacks on mobile platforms often require rooting a device for elevated privileges, reverse-engineering, modification of the application or to exploit platform-specific vulnerabilities.

3.1.3 Web Application

Web applications are browser-based implementations using web technologies (e.g. HTML, JavaScript, WebAssembly). They are accessible through standard web browsers on both desktop and mobile platforms via URL and require no installation, however, they must be compatible with the various available browsers users might use. The execution environment is defined by the browser security model, and hardware access is limited to browser APIs (e.g., MediaStream API for camera access). One needs to consider that different browsers have different security configurations (e.g. Chrome or LibreWolf). As web applications are typically accessible through desktop systems where users in unsupervised settings have root permissions, injection can occur at the OS-level to spoof video input and hardware information before it reaches the browser and therefore all methods relevant to Desktop Applications are relevant here, too.

3.2 Data Processing Architecture

Beyond the platform type, the way the face biometric system is integrated into the application determines the injection attack surface. While the platform type (Desktop, Mobile, Web) governs which client-side injection methods are feasible, the processing architecture determines whether network-based injection methods must additionally be considered.

3.2.1 Client-side Processing

In native or SDK-based integrations, the face biometric capture, processing, and countermeasures (e.g. presentation attack or deepfake detection) occur entirely on the client device. The video stream remains local and is processed within the application's execution environment.

3.2.2 Server-side Processing

In API-based integrations, the face biometric capture occurs on the client, but video data or frames are transmitted to a remote server for processing and the evaluation of countermeasures. Additionally, it is also possible that applications perform (partial) evaluations on the client device and send preprocessed data to the remote server. This architecture exposes additional attack surface at the network transport layer, making network-based injection methods relevant in addition to client-side injection methods.

3.3 Data Handling

Whether the TOE processes biometric data as a live stream or as persisted image/video files determines which injection methods are feasible. An IAM that can only deliver files is ineffective against a TOE that exclusively consumes live streams. On the other hand, an IAM capable of injecting a continuous stream can in most cases target both data handling types, provided that the application recording the file accepts the injected stream as its input source.

3.3.1 Image/Video Files

The TOE captures biometric data and persists them as image or video files before processing or transmitting them. This makes the TOE susceptible to file-based injection methods such as file replacement (►Section D.4.1), in addition to stream-capable methods that can also deliver their output as files.

3.3.2 Live Streams

The TOE processes biometric data as a continuous stream, either locally or transmitted to a backend, without persisting intermediate files. Only injection methods that can deliver frames continuously to the application or intercept the stream in transit are applicable.

3.4 IAI Real-Time Capability

Injection attack instruments differ in whether their output must be prepared before an attack session or can be generated during the session. An instrument capable of real-time generation can always also be used as pre-rendered material. Some instruments allow real-time generation but at reduced output quality compared to pre-rendering, depending on the framework and available computational resources.

3.4.1 Pre-rendered

The instrument's output is fully generated before the attack session begins. Pre-rendered material can still be played back as a stream during the session using any compatible injection method. However, if the session includes time-constrained challenges, the attacker can only attempt to predict the expected responses or provide generic responses.

3.4.2 Real-time

The instrument generates its output live during the attack session, allowing it to react to session-specific challenges.

3.5 Injection Attack Methods

Video injection attacks can be performed at different technical layers, ranging from the application level down to hardware emulation. ▶Table 3.1 categorizes injection attack methods by the layer at which they operate and indicates their applicability across desktop and mobile application types. Web applications are not listed as a separate column, as described in ▶Section 3.1, all methods applicable to desktop also apply to web.

IAM-Nr.	Attack Method	Description	Desktop	Mobile
1.	Software-based injection methods			
1.1	Virtual Cameras	Virtual camera devices that register as a video source, either as user-space applications using OS APIs/frameworks or as kernel modules/drivers that are treated by the OS as hardware.	X	
1.2	Kernel-level Modification of Camera Driver	Modification of the camera driver at the kernel level to intercept and replace captured frames or to gain detailed insight into requests made to the camera. On mobile this requires a custom kernel and in practice overlaps with the customized OS method (IAM 1.4).	X	(X+)
1.3	Emulated System	Execution of the application in an emulated or virtual environment with a controllable camera.	(X)	X
1.4	Customized OS / Runtime Environment	Modification of an open-source OS image at the camera hardware abstraction layer or at the framework / managed-runtime layer above it, so that the system-wide camera source or its framework-level API is fed from e.g. a video file, pipe, or network socket instead of from a real sensor.	(X)	X+
2.	Hardware-based injection methods			
2.1	USB Video Class - based injection	USB device that poses as legitimate video source to the OS but can itself be fed with controlled video sources.	X	
3.	Network-based injection method			
3.1	Man-in-the-Middle Attack	Interception of client/server communication to replace transmitted data with manipulated data.	X	X / X+
4.	Application-level injection			
4.1	File Replacement	Replacement of recorded video files in local storage before processing by the TOE.	X	X / X+
4.2	API Hooking	Intercepting and replacing function calls within the TOE application, e.g., to substitute camera frames returned by the camera API with manipulated content.	X	X / X+
4.3	Modified / Custom Client	Custom or rewritten client that communicates with the server by mimicking the TOE protocol.	X	X / X+
4.4	System Library / Dependency Substitution	Replacement of dynamically linked libraries the application loads at runtime (e.g. TLS or codec libraries), so the application calls into attacker-controlled code without modifying the application binary itself.	X	X / X+

Table 3.1 List of possible injection attack methods sorted by the level how the method is injected. A (+) marks methods that require elevated privileges on the mobile system, whether obtained by rooting a stock device or inherent to running a self-built or modified environment (e.g. a custom OS image or custom kernel). A (X) marks a method that is applicable but same results can be achieved with simpler methods in the same environment. X / X+ marks systems where it depends on the implementation whether privileged access is required.



Caution

Additional IAMs that are conceivable to the authors of this evaluation guidance but not yet reproduced or provably demonstrated are listed in ▶Appendix B.

3.6 Injection Attack Instruments

While injection attack methods describe how video content is injected into the system, injection attack instruments define what malicious content is being injected. ▶Table 3.2 categorizes different types of attack payloads that can be delivered through the injection methods outlined in the previous section that can target any module discussed within this document. ▶Table 3.3 categorizes the IAI classes that specifically target face data and ▶Table 3.4 categorizes the IAI classes that target ID document data.

3.6.1 Generic Injection Attack Instruments

IAI-Nr.	Attack Instrument	Description
G1	Genuine Attacks	
G1.1	Replay Attack	Inject a recording of a legitimate user (e.g. of its face or ID document).
G1.2	Relay Attack	Inject a live video produced by relaying selected TOE session events (e.g. challenge-response prompts) in real time to a controlled application that captures the reaction of a (typically unwitting) human at a separate endpoint and feeds the result back into the TOE via the established IAM.
G2	Adversarial Attacks	
G2.1	Digital Adversarial Perturbations	Calculate an adversarial noise pattern per frame at runtime on surrogate models and overlay it on the frames sent to the target system to evade detection, image quality assessment and/or comparison.
G2.2	Trained universal pattern attacks	Pre-train a single universal noise pattern on surrogate models that evades detection, image quality assessment and/or comparison when overlaid on any frame, avoiding per-frame optimization at runtime.
G2.3	Trained adversarial generator network attacks	Train an image-to-image network on surrogate models that outputs a per-frame noise pattern to evade detection, image quality assessment and/or comparison, replacing per-frame optimization with fast inference.
G3	Post Processing of Manipulations	
G3.1	Lighting & Color Correction	Adjust illumination, color temperature, reflections to match target environment.
G3.2	Quality Degradation (Artifact Masking)	Intentionally degrade quality to mask attack artifacts or match camera characteristics.
G3.3	Temporal Manipulations	Frame-level operations to improve temporal coherence or evade detection.
G3.4	Variation of Distance	Vary size of the object of interest (e.g. a face) by changing the distance from the camera.
G3.5	Variation of Background	Use varied backgrounds in the video of the object of interest, e.g. a purely white background behind a face or a very colorful one.
G3.6	Sensor Noise Synthesis	Add a consistent, camera-realistic noise signature (e.g. photo-response non-uniformity) to the injected frames so they match the statistics of a genuine sensor, optionally that of a specific claimed device.

Table 3.2 List of possible injection attack instrument classes applicable to multiple modules sorted by attack categories.

3.6.2 Face Injection Attack Instruments

IAI-Nr.	Attack Instrument	Description
F1	Face Synthesis and Manipulation Techniques	
F1.1	Identity-Trained Face Swapping	Train a face swapping model on collected images/videos of the target identity to place the target's face onto the attacker.
F1.2	One-Shot Face Swapping	Face swapping using a single reference image of the target identity, without requiring training on that identity.

IAI-Nr.	Attack Instrument	Description
F1.3	Single Image Animation	Generate a video from a single still photograph of the target identity using motion transfer from a driving video/webcam, or by a driving audio, or by animating the still with a text-prompted image-to-video model.
F1.4	Video Reenactment	Transfer facial expressions and head movements from a driving source onto a target face in an existing video, either replacing the full head or only specific regions, e.g. the mouth while keeping the rest of the genuine video. Alternatively by using the video to train a model to generate a new video of the person with reenacted pose.
F1.5	3D Rendered Faces	Render the head of the target identity using 3D rendering software and e.g. control it via motion capturing.
F1.6	Fully Generated Faces	Generate a video of a fully synthetic face using generative AI, intended to be used for synthetic-identity attacks.
F3	Post Processing of Manipulations	
F3.1	Face Enhancement & Restoration	Apply super-resolution or restoration to improve face quality and mask artifacts.

Table 3.3 List of possible injection attack instrument classes for the module face sorted by attack categories.

3.6.3 ID Document Injection Attack Instruments

IAI-Nr.	Attack Instrument	Description
D1	ID Document / Security Feature Synthesis	
D1.1	Full ID Document Projection	Render a complete image of the target ID document, with or without security features, and composite it onto a physical carrier card presented in the video, applying a per-frame perspective transform that matches the card's position, orientation and presented angle. The carrier may be a blank card or a genuine document over which the image is composited at reduced opacity to borrow its genuine security features.
D1.2	Security Feature Projection	Composite only the security features (e.g. holograms, optically variable ink) onto a (fraudulent) ID document presented in the video, applying a per-frame perspective transform that matches the presented angle, while relying on the physical card for the remaining appearance.
D1.3	Partial Document Projection	Composite only a segmented region of a presented ID document, e.g. the facial portrait or a printed identity attribute. Replace the region opaquely, or blend it transparently over a presented genuine document. Edits of the facial region may use techniques from ▶Section 3.6.2.
D1.4	Copy-Move of Segmented Areas	Record two genuine ID documents simultaneously under matched conditions, i.e. with similar angle and distance to the light source and the recording device for both. Copy segmented areas from the source document onto the target ID document and present only the crop of the composited target ID document.
D1.5	Fully Generated ID Documents	Generate a video of the target ID document, possibly using a reference image of the target ID document, using generative AI.

Table 3.4 List of possible injection attack instrument classes for the module ID documents sorted by attack categories.

4 Pre-Evaluation Phase

Before the system is evaluated, a pre-evaluation of the system is mandatory so the evaluators can get familiar with the system and determine which attacks are even feasible for the TOE. For this purpose, a test system is required for evaluations targeting *substantial* or higher as described in ▶Section 2.1.2.

4.1 Documentation

Nr.	Requirement
[INI-DOC-01]	For the pre-evaluation of the TOE the evaluator SHALL document:
[INI-DOC-01a]	- the evaluation environment.
[INI-DOC-01b]	- the TOE including software version.
[INI-DOC-01c]	- the application type relevant to the TOE and how data is processed and handled by it.
[INI-DOC-01d]	- used tools, their versions and configurations used for IAM and IAI.
[INI-DOC-01e]	- custom tools and extension or modification of existing tools developed to produce the IAM and IAI.
[INI-DOC-01f]	- any additional devices used including software and hardware version.
[INI-DOC-01g]	- if IAM and IAI listed in ▶Appendix D and ▶Appendix E are not attempted during the pre-evaluation, the specific reason why they are not deemed relevant.
[INI-DOC-02]	The documentation SHALL be written in a manner that allows an independent party, with expertise in the field, to reproduce the pre-evaluation.
[INI-DOC-03]	The documentation SHALL include a description of the systematic process followed during the pre-evaluation, including:
[INI-DOC-03a]	- if applicable, which subsystems of the TOE were tested individually and which were deactivated or bypassed during testing, including the rationale for each configuration.
[INI-DOC-03b]	- the combinations of IAM and IAI applied to each (sub)system configuration and if reasonable the order in which they were pursued.
[INI-DOC-03c]	- the criteria used to prioritize or escalate specific attack paths.
[INI-DOC-03d]	- the reasons why attempted IAM or IAI were discontinued during the pre-evaluation.
[INI-DOC-03e]	- any intermediate findings that influenced subsequent testing decisions.
[INI-DOC-04]	The documentation SHALL include a consolidated summary of the pre-evaluation findings that provides the basis for the evaluation phase, including:
[INI-DOC-04a]	- if applicable, the identified potential vulnerabilities in subsystems and their assessed severity with respect to the TOE.
[INI-DOC-04b]	- the IAM and IAI combinations selected for the evaluation phase and the rationale for their selection based on pre-evaluation results.
[INI-DOC-04c]	- any limitations encountered during the pre-evaluation that may affect the scope or conduct of the evaluation phase.
[INI-DOC-04d]	- where pre-evaluation results are inconclusive, the remaining uncertainty and how it is addressed in the evaluation phase.

Table 4.1 Requirements on documentation of the system.

Note to ▶INI-DOC-01a: The documentation of the evaluation environment includes both the laboratory space used for video recordings (live or for replay attacks), as well as the generic equipment used for the pre-evaluation process. This can be performed via photo documentation and a description of the equipment.

Note to ▶INI-DOC-01c: If multiple application types (i.e. both desktop and mobile environments) are relevant to the TOE e.g. when testing a generic SDK, the worst case that provides the highest potential to injection attacks is relevant. If the evaluation laboratory is indecisive which application type is the worst case, or if multiple implementations are promising to be vulnerable, the evaluation laboratory should perform the pre-evaluation on all types that it assumes to be vulnerable.

Note to ►INI-DOC-01g: A reason can be that a specific injection method is not applicable to the architecture of the RIDP system, e.g. if the application live streams the video feed, the file replacement method is not relevant if no files are transferred.

Note to ►INI-DOC-03: The purpose of documenting the systematic process is to ensure traceability of the pre-evaluation methodology. Since the evaluation phase builds upon pre-evaluation results, the rationale behind each testing decision shall be comprehensible to an independent reviewer. This includes documenting why certain (sub)system configurations were chosen for isolated testing, as vulnerabilities in individual subsystems may be obscured when the full system is operational.

Note to ►INI-DOC-04: The pre-evaluation summary serves as the primary input for scoping and planning the evaluation phase. It shall provide sufficient detail for the evaluator to justify the selected attack scenarios and for the certification body to assess whether the evaluation scope is adequate.

Note to ►INI-DOC-04d: This is a generic clause to cover cases where the evaluation laboratories for example have observed some spurious behavior from the system but were unable to properly reproduce it within the evaluation time.

4.2 Initial Functional Test of the IAD System

Nr.	Requirement
[INI-FUN-01]	The evaluation laboratory SHALL evaluate the general functionality of the TOE by bona fide tests.
[INI-FUN-02]	The initial functional tests SHALL be performed with at least 10 different identities.
[INI-FUN-03]	The initial functional tests SHOULD be performed with multiple relevant technical setups (varied cameras, mobile devices, etc.).
[INI-FUN-04]	The initial functional tests SHOULD be performed with varying conditions (lighting conditions, test person, etc.).

Table 4.2 Requirements on initial functionality of the system.

Note to ►INI-FUN-01 & ►INI-FUN-02: The system SHALL NOT classify bona fide attempts without injection attempts as attacks beyond a documented BPCER stated by the manufacturer. This shall also be verified during the evaluation phase to exclude cheating attempts on the evaluation.

Note to ►INI-FUN-03: For web applications different browsers (Chrome, Firefox, ...) or different browser settings with more or less restrictions make sense for injection attempts. Also the variation of the webcam used for a browser and what capabilities are relevant should be determined. Similar for mobile applications, different mobile phones on different OS versions can make sense to fallback to more vulnerable systems in the pre-evaluation and evaluation phase for injection attempts. The manufacturer may adjust thresholds and configurations depending on the technical setup used, which should also be verified by the bona fide tests.

Note to ►INI-FUN-04: The laboratory should assess the functional limits the system has in the genuine case to avoid to conflate these with injection induced limits.

4.3 Pre-Evaluation Process

In the following the requirements on performing the pre-evaluation process are specified. This includes generic tasks that the testing laboratory shall have performed in preparation before the evaluation task, as those should not be included in the evaluation time specified in the requirements of ►Section 5.3.

4.3.1 General Requirements

Nr.	Requirement
[PRE-PRO-01a]	Prior to the pre-evaluation, the evaluation laboratory SHALL have prepared generic implementations of known applicable IAM relevant to the targeted evaluation level and for the application type.
[PRE-PRO-01b]	Prior to the pre-evaluation, the evaluation laboratory SHALL have prepared generic pipelines and frameworks to realize applicable IAI relevant to the targeted evaluation level.

Nr.	Requirement
[PRE-PRO-02]	The evaluation laboratory SHALL predetermine, which IAM and which IAI species will be best suited to succeed depending on TOE architecture and prioritize the pre-evaluation accordingly. The prioritization SHALL ensure that all relevant attack vectors are still evaluated with a reasonable evaluation depth.
[PRE-PRO-03]	The evaluator SHALL optimize the IAM and IAI in the pre-evaluation process to optimally target the TOE. For evaluation level <i>substantial</i> or higher, the test system as described in ▶Section 2.1.2 SHALL be used for this purpose.
[PRE-PRO-04]	A well-documented environment SHALL be maintained during the pre-evaluation.
[PRE-PRO-05]	If applicable, network traffic between application and any other service (e.g. backend servers or platform integrity service provider) SHALL be monitored and for evaluation level <i>substantial</i> or higher, the test environment SHALL allow the evaluators to inspect and decrypt the network traffic.
[PRE-PRO-06]	For mobile applications, measures to evade integrity checks with respect to the app and device SHALL be prepared. This includes measures to evade root detection or platform integrity attestation checks.
[PRE-PRO-07]	For evaluation level <i>high</i> , the evaluation laboratory SHALL identify subsystems of the TOE that contribute to the injection attack detection and select those where individual testing is expected to support the optimization of IAM and IAI for the evaluation of the overall system.
[PRE-PRO-07a]	- For selected subsystems, the evaluator SHALL attempt to determine applicable IAM by selectively deactivating or bypassing other subsystems.
[PRE-PRO-07b]	- The evaluator SHALL use findings from individual subsystem testing to refine and optimize IAM and IAI with the objective of overcoming the combined detection mechanisms of the TOE.
[PRE-PRO-08]	For evaluation level <i>substantial</i> and <i>high</i> , the evaluation laboratory SHOULD define, create and optimize additional IAM and IAI beyond those listed in this document during the pre-evaluation phase.
[PRE-PRO-09]	The evaluation laboratory SHALL structure the pre-evaluation phase such that all required analyses are completed and optimizations are progressed to a level of maturity sufficient to confidently conduct the evaluation phase, while preserving sufficient time to do so within the total time limit defined in ▶Section 5.3.
[PRE-PRO-10]	If during the pre-evaluation phase the evaluation laboratory is sure that a robust attack path with a combination of an IAM and an IAI is found, it MAY at any time test it on the TOE used within the evaluation phase to determine whether the evaluation can be finished early. However, if the attempts are not successful it SHALL return to the structured evaluation process by finishing the pre-evaluation phase first.

Table 4.3 Requirements on pre-evaluation process of the system.

Note to ▶PRE-PRO-02: The consequence of the prioritization can not be that certain attack vectors are left unevaluated because of the limited evaluation time.

Note to ▶PRE-PRO-03: ▶Appendix D and ▶Appendix E go into detail on optimization aspects for the various injection methods and instruments respectively.

Note to ▶PRE-PRO-04: Refer to ▶Section 4.1 for requirements on the documentation.

Note to ▶PRE-PRO-05: To be able to estimate vulnerabilities to network based attacks, the test system should provide access to monitor the traffic in a decrypted format. A MITM, as described in ▶Section D.3.1, should be implemented separately to this option.

Note to ▶PRE-PRO-07: Testing selected subsystems in isolation lets the evaluator determine whether an applicable IAM exists for the TOE systematically, instead of by trial and error against the full system. The reduced complexity makes it feasible to identify each subsystem's detection capabilities and to refine attacks against them within the available evaluation time.

Note to ▶PRE-PRO-08: The evaluator can attempt to use the test system and the obtained documentation of the TOE described in ▶Chapter 2 to design TOE specific IAM or IAI.

4.3.2 Injection Attack Method Development

During the pre-evaluation, the methods listed in ▶Section 3.5 are assessed. For this purpose the following requirements are specified such that all publicly known attack methods are considered in this phase.

4.3.2.1 Software-based Methods

The following requirements include the methods that have the goal to simulate, by software, a camera that can be fed from a controlled source with frames e.g. by reading a pipe, a network socket or a video file.

Nr.	Requirement
[PRE-MET-01a]	For desktop/web applications, the virtual camera injection method SHALL be tested.
[PRE-MET-01b]	For desktop/web applications, the injection via a modified camera driver SHALL be tested.
[PRE-MET-01c]	For mobile applications, the emulator based injection method SHALL be tested.
[PRE-MET-01d]	For mobile applications on Android, a customized OS SHALL be tested.

Table 4.4 Requirements on software-based injection attack method development.

Note to ►PRE-MET-01a - ►PRE-MET-01d: Refer to ►Section D.1 for details.

4.3.2.2 Hardware-based Methods

The following requirements include the methods that have the goal to simulate, by hardware, a camera that can be fed from a controlled source with frames e.g. via an HDMI socket.

Nr.	Requirement
[PRE-MET-02]	For desktop/web applications, the laboratory SHALL attempt to use a controllable UVC-based device as video source.

Table 4.5 Requirements on hardware-based injection attack method development.

Note to ►PRE-MET-02: Refer to ►Section D.2 for details.

4.3.2.3 Network-based Methods

The following requirements include the methods that target the data transmission between the application and its backend services, where the goal is to intercept and modify the video stream in transit.

Nr.	Requirement
[PRE-MET-03]	If applicable to the TOE, the evaluation laboratory SHALL attempt to read and modify the data stream to a backend service by man-in-the-middle attacks.

Table 4.6 Requirements on network-based injection attack method development.

Note to ►PRE-MET-03: Refer to ►Section D.3 for details.

4.3.2.4 Application-level Methods

The following requirements include the methods that target the TOE's client application itself, with the goal to feed it attacker-controlled data or to bypass its client-side security checks, e.g. by replacing a stored video file, hooking API calls or substituting linked libraries.

Nr.	Requirement
[PRE-MET-04]	The evaluation laboratory SHALL determine the feasibility to reverse engineer the application, this SHALL include the following points:
[PRE-MET-04a]	If data is not being live streamed, but stored temporarily to a file first, the laboratory SHALL attempt to replace the video file before it is sent.
[PRE-MET-04b]	The application SHALL be analyzed for API hooking points e.g. to replace camera data / metadata, or to skip/spoof client-sided security checks. If applicable the testing laboratory SHALL attempt to inject via API hooking.
[PRE-MET-04c]	If the application code is obfuscated, the laboratory SHALL determine the feasibility or estimate the effort to deobfuscate the code for e.g. the relevant hooks to the camera or security function calls.
[PRE-MET-04d]	If feasible the laboratory SHALL attempt to write a simplified client that performs expected calls to the backend, skipping internal client-side security evaluations and sending the expected data.

Nr.	Requirement
[PRE-MET-04e]	The laboratory SHALL determine whether the application loads dynamically linked system libraries and, if applicable, SHALL attempt injection by substituting these libraries or by manipulating the dynamic linker search path.

Table 4.7 Requirements on injection attack method development that target the client-sided application of the TOE.

Note to ►PRE-MET-04a - ►PRE-MET-04e: Refer to ►Section D.4 for details.

4.3.3 Injection Attack Instrument Development

During the pre-evaluation, the instruments listed in ►Section 3.6 are prepared and optimized. For this purpose the following requirements are specified such that at least all publicly known attack instruments are considered in this phase.

4.3.3.1 Quality Requirements

The following requirements specify the quality that an injection attack instrument shall reach so that it is consistent with a bona fide presentation and can pass the biometric and document verification of the TOE.

Nr.	Requirement
[PRE-QUA-01]	Any IAI used for facial comparison SHALL reach a biometric comparison score exceeding the system threshold, except if using a non-matching instrument is intended.
[PRE-QUA-02]	The laboratory SHOULD optimize its IAI during pre-evaluation to achieve a high quality for the biometric appearance of the instrument.
[PRE-QUA-03]	IAIs targeting ID documents SHALL match to the dimensions, data fields and reference portrait position of a genuine ID document type.

Table 4.8 Requirements on quality of used injection attack instruments.

Note to ►PRE-QUA-02: Where ►PRE-PRO-03 requires that IAI are optimized to target the TOE, this requirement is concerned with optimization in terms of the biometric comparison score. The biometric score can be optimized with the test system while deactivating all IAD subsystems to optimally target the biometric subsystem of the TOE.

Note to ►PRE-QUA-03: This requirement concern the consistency of the document instrument with respect to the document authentication of the TOE, analogous to ►PRE-QUA-01 for the biometric comparison score. Where the TOE authenticates the document cryptographically, e.g. by reading the chip via NFC with passive and active authentication or by comparison against an authoritative register, and this verification cannot be reproduced through the established IAM, these instruments are out of scope.

4.3.3.2 Genuine Attack Instruments

The following requirements include the instruments that use genuine recordings of the target identity, e.g. replayed or relayed videos, without synthetic manipulation of the face.

Nr.	Requirement
[PRE-INS-01a]	The laboratory SHALL use recordings of genuine subjects that are visually consistent with bona fide presentations in terms of image quality, lighting and appearance. If the challenge-response tasks are enumerable and if feasible, the laboratory SHALL prepare versions of the IAI for every possible scenario, otherwise select a certain subset of scenarios at random to prepare IAIs for those scenarios.
[PRE-INS-01b]	If applicable, the laboratory SHALL splice multiple videos dynamically during the capture process to respond appropriately to challenge-response tasks.
[PRE-INS-01c]	The laboratory SHALL attempt to relay TOE session events in real time to a controlled application that captures the reaction of a target identity at a separate endpoint and feeds the result back into the TOE via the established IAM.
[PRE-INS-01d]	If applicable, the laboratory SHALL assess the feasibility of injecting replay / relay attack for both facial and ID document presentations.

Table 4.9 Requirements on injection attack instrument development of instruments using genuine faces.

Note to ►PRE-INS-01b - ►PRE-INS-01c: Refer to ►Section E.1 for details.

4.3.3.3 Face Synthesis & Manipulation Instruments

The following requirements include the instruments that synthesize or manipulate the face of the target identity, e.g. by face swapping, reenactment, 3D rendering or fully generating the face.

Nr.	Requirement
[PRE-INS-02a]	The laboratory SHALL train face swap models on the target identity and create pre-computed high quality deepfakes with the trained models.
[PRE-INS-02b]	The laboratory SHALL train face swap models on the target identity and use them in a real-time setting.
[PRE-INS-02c]	The laboratory SHALL use pre-trained one-shot face swapping methods that are based on single images of the target identity.
[PRE-INS-02d]	The laboratory SHALL use reenactment methods that animate a single image of the target identity.
[PRE-INS-02e]	The laboratory SHALL use reenactment methods that manipulate a video of the target identity.
[PRE-INS-02f]	The laboratory SHALL use optimal data, e.g. face images or 3D scans, of the target identity, except when the usage of non optimal data is intended specifically as attack instrument.
[PRE-INS-02g]	The laboratory SHALL attempt to use target identities with similar traits to the evaluator (age, hair color, beard, etc.).
[PRE-INS-02h]	The laboratory SHALL attempt to use target identities with facial features that are more easily to synthesize (no beard, no glasses, etc.).
[PRE-INS-02i]	The laboratory SHALL render the head of the target identity with 3D rendering software and animate it, e.g. driven by motion capture, to produce a video of the target identity.
[PRE-INS-02j]	The laboratory SHALL completely AI-generate a video of a fully synthetic face using generative models, for synthetic-identity attacks where the presented identity is not bound to a genuine reference using an authoritative source.

Table 4.10 Requirements on development of injection attack instruments belong to the class of face synthesis and face manipulations

Note to ►PRE-INS-02a - ►PRE-INS-02j: Refer to ►Section E.2 for details.

4.3.3.4 ID Document / Security Feature Synthesis Instruments

The following requirements apply where the TOE authenticates the ID document through the video stream.

Nr.	Requirement
[PRE-INS-03a]	The laboratory SHALL render a complete synthetic image of the target ID document and project it onto a physical carrier card presented in the video, matching the layout, fonts and printed data of an ID document type accepted by the TOE.
[PRE-INS-03b]	The laboratory SHALL composite security features of the document, e.g. holograms or optically variable ink, onto a carrier card with a view-dependent appearance that reacts to the presented angle.
[PRE-INS-03c]	The laboratory SHALL digitally edit a segmented region of a presented document, e.g. the facial portrait or a printed identity attribute, replacing it opaquely and, over a genuine document, blending it at reduced opacity so an overlapping genuine security feature shows through. For the facial portrait, the laboratory MAY use the face synthesis and manipulation instruments of ►Table 4.10, selecting those appropriate for the TOE and the target ID document.
[PRE-INS-03d]	The laboratory SHALL digitally copy a segmented region from a genuine source document onto a genuine target ID document, both recorded under similar angle, distance and lighting conditions, and present only the crop of the composited target ID document.
[PRE-INS-03e]	The laboratory SHALL completely AI-generate a video of a synthetic ID document using generative models, optionally conditioned on a reference image of the target ID document.

Table 4.11 Requirements on development of injection attack instruments belonging to the class of ID document and security feature synthesis.

Note to ►PRE-INS-03a - ►PRE-INS-03e: Refer to ►Section E.3 for details.

Note to ►PRE-INS-03c: The facial portrait of a document is a biometric reference, so editing it is equivalent to a face manipulation attack carried into the document. The laboratory is not expected to reproduce every face synthesis and manipulation instrument inside the document context. But it is expected that it selects the

instruments and the editing depth that are relevant for the TOE and the target ID document type based on the pre-evaluation findings, and documents the selection.

4.3.3.5 Adversarial Attack Instruments

The following requirements on adversarial attack instruments apply to evaluations targeting evaluation level *substantial* or *high*.

Nr.	Requirement
[PRE-INS-04a]	For transfer-based adversarial attacks, the laboratory SHALL use a sufficiently large and diverse set of surrogate models for each targeted subsystem (face comparison, deepfake detection, and, if applicable, face quality estimation). The surrogate ensemble SHALL cover a variety of architectures and, where relevant, training datasets to maximize the likelihood of transferability to the target system.
[PRE-INS-04b]	For transfer-based adversarial attacks, the laboratory SHALL evaluate which subset of surrogate models is best suited for a successful attack.
[PRE-INS-04c]	The laboratory SHALL use transfer-based adversarial noise attacks against face comparison adding adversarial noise to the genuine camera output of the filmed evaluator.
[PRE-INS-04d]	The laboratory SHALL use transfer-based trained universal pattern attacks against face comparison adding the adversarial pattern to the genuine camera of the filmed evaluator.
[PRE-INS-04e]	The laboratory SHALL use transfer-based trained adversarial generator network attacks against face comparison converting the genuine camera output of the filmed evaluator.
[PRE-INS-04f]	If an IAI is not successful against the biometric component of the TOE but successful against the deepfake detection component the laboratory SHALL use transfer-based adversarial noise attacks against face comparison adding adversarial noise to the IAI output. This is not required if the IAI is an adversarial attack against face comparison.
[PRE-INS-04g]	If an IAI is not successful against the biometric component of the TOE but successful against the deepfake detection component the laboratory SHALL use transfer-based universal adversarial pattern attacks against face comparison adding the adversarial pattern to the IAI output. This is not required if the IAI is an adversarial attack against face comparison.
[PRE-INS-04h]	If an IAI is not successful against the biometric component of the TOE but successful against the deepfake detection component the laboratory SHALL use transfer-based trained adversarial generator network attacks against face comparison converting the IAI output. This is not required if the IAI is an adversarial attack against face comparison.
[PRE-INS-04i]	If an IAI is not successful against the deepfake detection of the TOE, the laboratory SHALL use transfer-based adversarial noise attacks against deepfake detection adding adversarial noise to the IAI output. This is not required if the IAI is an adversarial attack against deepfake detection.
[PRE-INS-04j]	If an IAI is not successful against the deepfake detection of the TOE, the laboratory SHALL use transfer-based universal adversarial pattern attacks against deepfake detection adding the adversarial pattern to the IAI output. This is not required if the IAI is an adversarial attack against deepfake detection.
[PRE-INS-04k]	If an IAI is not successful against the deepfake detection of the TOE, the laboratory SHALL use transfer-based trained adversarial generator network attacks against deepfake detection converting the IAI output. This is not required if the IAI is an adversarial attack against deepfake detection.
[PRE-INS-04l]	If an IAI is not successful against the face quality estimation of the TOE, the laboratory SHALL use transfer-based adversarial noise attacks against face quality estimation adding adversarial noise to the IAI output. This is not required if the IAI is an adversarial attack against face quality estimation.
[PRE-INS-04m]	If an IAI is not successful against the face quality estimation of the TOE, the laboratory SHALL use transfer-based universal adversarial pattern attacks against face quality estimation adding the adversarial pattern to the IAI output. This is not required if the IAI is an adversarial attack against face quality estimation.
[PRE-INS-04n]	If an IAI is not successful against the face quality estimation of the TOE, the laboratory SHALL use transfer-based trained adversarial generator network attacks against face quality estimation converting the IAI output. This is not required if the IAI is an adversarial attack against face quality estimation.

Table 4.12 Requirements on adversarial attack instruments

Note to ►PRE-INS-04c - ►PRE-INS-04n: Refer to ►Section E.4 for details.

5 Evaluation Phase

Once the pre-evaluation phase is concluded and the laboratory has established which IAMs and IAIs are feasible, the evaluation is performed on the TOE as it will be available in the market. The following section specifies the general requirements, metrics, minimal tests and time constraints for this phase, with the aim of a confident vulnerability assessment.

5.1 General Requirements

Nr.	Requirement
[EVA-GEN-01]	The testing laboratory SHALL perform an evaluation using the evaluation metric from ▶Section 5.2 for at least the duration specified in ▶Section 5.3 and covering at least the tests of ▶Section 5.4.
[EVA-GEN-02]	In contrast to the pre-evaluation phase for evaluation levels <i>substantial</i> or higher, during the evaluation phase the IAD evaluation SHALL be performed with the TOE, which will be available in the market, without the access to intermediate scores, decision logics or a deobfuscated application. Organisational measures such as banning or flagging of IP addresses that hinder the reproducibility of an attack SHALL be deactivated for an efficient usage of time in the evaluation phase.
[EVA-GEN-03]	The evaluator SHALL cover all IAM that have proven to be feasible during the pre-evaluation on the test-system.
[EVA-GEN-04]	The evaluator SHALL cover all IAI that have proven to be feasible during the pre-evaluation on the test-system and which are relevant with the available IAM. The attack rating should be within the targeted evaluation level when the rating is combined with the possible IAM.
[EVA-GEN-05]	The IAM and IAI SHALL be rated following the attack rating methodology of ▶CEN/TS 18099 as elaborated in ▶Appendix C.
[EVA-GEN-06]	The evaluation system SHALL be static during the evaluation.

Table 5.1 Requirements on evaluation process

Note to ▶EVA-GEN-02: If IAM determined in the pre-evaluation phase need to be adjusted to work on the TOE, the testing laboratory should do it. Furthermore, the withdrawal of access to intermediate scores and decision logic for the evaluation phase assumes that the production TOE does not leak this information through other means. A side channel that leaks score, timing or decision information on the production system (for example exploitable to optimize adversarial IAI in a black-box setting without the test system of ▶Section 2.1.2) would undermine this boundary. Where such a side channel is identified, the evaluator SHALL account for it in the attack rating.

Note to ▶EVA-GEN-06: To properly assess the system, the evaluation laboratory will need access to an evaluation system that is not continuously updated during the evaluation process.

5.2 Evaluation Metric

Nr.	Requirement
[EVA-MET-01]	Prior to the Evaluation Phase the evaluator SHALL perform the steps described in ▶Chapter 4.
[EVA-MET-02]	During the evaluation an evaluator SHALL present an IAI to the TOE with an identity different from his own.
[EVA-MET-03]	If the IAI can be trained or fine-tuned to the person driving the attack (for example on the driving video or a reference image of that person), the IAIs SHALL be personalised for the presenting evaluator.
[EVA-MET-04]	The IAD system SHALL be resilient to all attacks reaching the level corresponding to the targeted evaluation level. If an attack is found that can reproducibly bypass the system (see ▶EVA-MET-04d), and it is rated with a level relevant for the targeted evaluation level, the evaluation result is FAIL.
[EVA-MET-04a]	- for evaluation level <i>normal</i> the TOE SHALL be resistant to all attacks up to attack level Enhanced-Basic.
[EVA-MET-04b]	- for evaluation level <i>substantial</i> the TOE SHALL be resistant to all attacks up to attack level Moderate.
[EVA-MET-04c]	- for evaluation level <i>high</i> the TOE SHALL be resistant to all attacks up to attack level High.

Nr.	Requirement
[EVA-MET-04d]	In case that 3 injection attempts with a single IAM and IAI combination are classified as bona-fide for one evaluator (injected identity) the evaluation result is FAIL and the evaluator can stop testing. For the minimum number of injection attempts and identities see ▶EVA-MTC-04.
[EVA-MET-05]	The FNMR of the full system SHALL be estimated during the Evaluation Phase with bona fide presentations at random times in between IAI attacks and it SHALL NOT be significantly above the FNMR stated by the manufacturer (except due to statistical variance because of a low sample size). If the FNMR deviates strongly during the Evaluation Phase from the expected value, the evaluation result is FAIL.
[EVA-MET-06]	If the evaluation result is FAIL for the targeted evaluation level but the TOE could still pass at a lower evaluation level, the manufacturer MAY choose to continue the evaluation at the lower level.
[EVA-MET-07]	If the evaluation result is FAIL but the manufacturer can remediate the vulnerability, the evaluation laboratory MAY decide whether the update requires a re-evaluation from the beginning or whether the changes are of such low impact that the evaluation can continue. If the evaluation continues, the changes made SHALL be documented.

Table 5.2 Requirements on evaluation metrics

Note to ▶EVA-MET-03: The personalisation concerns the driving side that produces a convincing live presentation. The identity injected towards the TOE remains a different one, as required by ▶EVA-MET-02.

Note to ▶EVA-MET-04: The passing criteria follows the definition from ▶CEN/TS 18099. The methodology for how reproducibility is derived follows the methodology from ▶BSI TR-03166.

Note to ▶EVA-MET-04d: The criterion of 3 successful injection attempts for an injected identity is derived from ▶BSI TR-03166. If this threshold is reached, the attack is considered reproducible.

Note to ▶EVA-MET-05: As the performance is assumed to be properly evaluated following the evaluation guidance of ▶BSI TR-03166, this requirement is in place to avoid for example scenarios, where the system adjusts its thresholds after detecting some IA and expects to be in a testing setup.

5.3 Fixed Time Methodology

Nr.	Requirement
[EVA-FTM-01]	The upper time limit for the IAD evaluation for evaluation level <i>normal</i> SHALL be 30 person-days.
[EVA-FTM-02]	The upper time limit for the IAD evaluation for evaluation level <i>substantial</i> SHALL be 60 person-days.
[EVA-FTM-03]	For evaluation level <i>high</i> , no fixed upper time limit applies. The evaluation SHALL be considered complete only once all feasible IAM and all relevant IAI identified in the pre-evaluation phase (see ▶Section 5.4) have been evaluated against attacks up to attack level High.
[EVA-FTM-04]	The testing laboratory SHALL assess within the pre-evaluation phase, at which point the optimization must be stopped and enough experience was collected to perform the evaluation phase in the remaining time.
[EVA-FTM-05]	An evaluation SHALL only be concluded with a PASS once the minimum test coverage according to ▶EVA-MTC-04 has been reached for every IAM and IAI in scope. The evaluation MAY be terminated earlier only if a reproducibly successful attack within the targeted evaluation level has already been established, in which case the result is FAIL (see ▶EVA-MET-04d).

Table 5.3 Requirements on upper time limits according to the fixed time methodology.

Note to ▶EVA-FTM-01 - ▶EVA-FTM-02: The time limit includes both pre-evaluation and evaluation phase.

Note to ▶EVA-FTM-03: The fixed-time approach follows the rationale of the fixed-time cybersecurity evaluation methodology (EN 17640 / FITCEM), which bounds the evaluation effort for assurance up to *substantial*. For evaluation level *high*, resistance against attack potential High must be established, for which a fixed time budget cannot provide sufficient assurance. The evaluation is therefore completion-driven rather than time-capped.

Note to ▶EVA-FTM-05: The time limits of ▶EVA-FTM-01 and ▶EVA-FTM-02 are hard upper bounds. If the applicable time limit is reached before the minimum test coverage has been achieved, the evaluation result is not PASS. The targeted evaluation level is not demonstrated. The pre-evaluation scoping according to ▶EVA-FTM-04 SHALL be performed such that the minimum test coverage is achievable within the time limit.

5.4 Minimal Test Coverage

5.4.1 General Test Coverage Requirements

Nr.	Requirement
[EVA-MTC-01]	If the analysis during the pre-evaluation phase resulted in the determination that an IAM or IAI is not feasible for the TOE, the corresponding tests do not need to be performed, provided a comprehensible and documented argument is stated as to why the attack is formally excluded.
[EVA-MTC-02]	If the analysis during the pre-evaluation phase resulted in that no IAM is feasible, the IAI do not have to be evaluated and the evaluation is PASS.
[EVA-MTC-03]	For each IAI that must be tested under the minimum test coverage requirements, the evaluation laboratory SHALL select the most capable feasible IAM for delivering that IAI and use it for the injection attempts required under ▶EVA-MTC-04. The most-capable IAM MAY differ between IAIs. The selection SHALL take into account the attack level rating of the IAM and IAI combination against the targeted evaluation level (see ▶EVA-MET-04a - ▶EVA-MET-04c). The laboratory MAY additionally vary the IAM across the injection attempts for the same IAI to broaden coverage.
[EVA-MTC-04]	Each IAI SHALL be injected at least 10 times with a minimum of 2 evaluators and 3 different target identities.
[EVA-MTC-05]	All IAM and IAI used during the evaluation phase SHALL be the optimized versions developed and validated during the pre-evaluation phase. The required depth of optimization scales with the targeted evaluation level.
[EVA-MTC-05a]	- for evaluation level <i>normal</i> , the optimized version SHALL be at least an off-the-shelf instrument that has been validated for applicability and basic effectiveness against the TOE during the pre-evaluation phase.
[EVA-MTC-05b]	- for evaluation level <i>substantial</i> and <i>high</i> , the optimization SHALL additionally include the development required in ▶Section 4.3.3.5 (adversarial attacks) and the other level-specific pre-evaluation requirements.
[EVA-MTC-06]	Where applicable, each IAI category SHALL additionally be tested in combination with the post-processing techniques (IAI G3.x / F3.x) that the pre-evaluation phase determined to be most promising for the given TOE. Not every available combination needs to be tested exhaustively, and the selection of tested combinations SHALL be justified based on the pre-evaluation findings.

Table 5.4 General requirements on test coverage for the evaluation phase.

Note to ▶EVA-MTC-01: The exclusion argument SHALL be traceable to the corresponding pre-evaluation documentation (see ▶INI-DOC-03 and ▶INI-DOC-04).

Note to ▶EVA-MTC-04: The 3 identities are in total across evaluators, not per evaluator.

Note to ▶EVA-MTC-06: Adversarial-attack combinations are covered in ▶Section 4.3.3.5 and by ▶EVA-MTC-05 (use of pre-evaluation-optimized versions).

5.4.2 Minimum Test Coverage for Genuine Attacks

Nr.	Requirement
[EVA-MTC-10]	The evaluation laboratory SHALL test the TOE against genuine attacks.
[EVA-MTC-10a]	Replay attacks (IAI G1.1) SHALL be tested, with recordings optimized based on pre-evaluation findings regarding recording conditions and quality.
[EVA-MTC-10b]	For TOE with challenge-response interactions, relay attacks (IAI G1.2) against the live face capture SHALL be tested.
[EVA-MTC-10c]	For TOE that authenticate the ID document through the video stream, replay attacks (IAI G1.1) of a genuine document SHALL be tested.
[EVA-MTC-10d]	For such TOE with a document challenge-response, relay attacks (IAI G1.2) of a genuine document SHALL be tested.

Table 5.5 Requirements on minimum test coverage for genuine attacks.

Note to ▶EVA-MTC-10a: For TOE without challenge-response interactions, an IAI generated live by a relay attack does not differ in substance from a pre-recorded video, so testing replay alone is sufficient to establish

the baseline genuine-face attack. For TOE with challenge-response interactions, replay attacks shall be tested to ensure that the TOE is not vulnerable because of e.g. low-entropy challenges or a low performance in differentiating random answers from correct ones.

Note to ▶EVA-MTC-10b: Refer to ▶Section E.1.2 for the relay scenario. The test probes whether the TOE can distinguish a live reaction produced in front of a different device (at the relay endpoint, by an unwitting human reacting to phished challenges) from one produced in front of the device presenting to the TOE.

Note to ▶EVA-MTC-10c: The condition on visual document authentication mirrors ▶EVA-MTC-14. Where the document is authenticated cryptographically and this verification cannot be reproduced through the established IAM, the tests MAY be excluded following ▶EVA-MTC-01.

5.4.3 Minimum Test Coverage for Face Swapping

Nr.	Requirement
[EVA-MTC-11]	The evaluation laboratory SHALL test the TOE against face swapping instruments using both identity-trained and one-shot approaches.
[EVA-MTC-11a]	For identity-trained face swapping (IAI F1.1), at least 2 distinct models representing different architectural approaches SHALL be tested.
[EVA-MTC-11b]	For one-shot face swapping (IAI F1.2), at least 3 distinct models SHALL be tested.

Table 5.6 Requirements on minimum test coverage for face swapping

Note to ▶EVA-MTC-11a: The 2 models SHALL represent distinct architectural approaches (e.g. autoencoder-based and GAN-based) to ensure coverage of different artifact profiles.

5.4.4 Minimum Test Coverage for Single Image Animation

Nr.	Requirement
[EVA-MTC-12]	The evaluation laboratory SHALL test the TOE against single image animation instruments (IAI F1.3) using at least 4 distinct models.
[EVA-MTC-12a]	The tested models SHOULD collectively cover the following driving modalities where applicable to the TOE:
[EVA-MTC-12a1]	- audio-driven animation, where animation is driven by audio input to generate lip movements and facial expressions.
[EVA-MTC-12a2]	- text-driven animation, where animation is driven by text prompts to generate facial movements.
[EVA-MTC-12a3]	- video-driven animation, where motion from a driving video is transferred to a still image of the target identity.

Table 5.7 Requirements on minimum test coverage for single image animation

5.4.5 Minimum Test Coverage for Video Reenactment

Nr.	Requirement
[EVA-MTC-13]	The evaluation laboratory SHALL test the TOE against video reenactment instruments (IAI F1.4) using at least 2 distinct models.
[EVA-MTC-13a]	The tested models SHOULD cover the following approaches where applicable to the TOE:
[EVA-MTC-13a1]	- partial facial region editing, where specific facial regions (e.g. mouth region) are reenacted while preserving authentic regions of the original video.
[EVA-MTC-13a2]	- generative model trained from video, where a generative model is trained on a target video to produce new video sequences with reenacted pose and expression.

Table 5.8 Requirements on minimum test coverage for video reenactment

5.4.6 Minimum Test Coverage for ID Document Attacks

Nr.	Requirement
[EVA-MTC-14]	For TOE that authenticate the ID document through the video stream, the evaluation laboratory SHALL test the TOE against ID document injection attacks.
[EVA-MTC-14a]	If the TOE accepts multiple ID document types (different document types, countries, etc.), the laboratory SHALL select up to 3 types it assesses as most promising to fake, or all accepted types where fewer than 3 are accepted, and test each selected type with at least 2 samples of different identities.
[EVA-MTC-14b]	Full document projection (IAI D1.1) SHALL be tested.
[EVA-MTC-14c]	Where the TOE verifies security features through the video stream, security feature projection (IAI D1.2) SHALL be tested.
[EVA-MTC-14d]	Partial document projection (IAI D1.3) SHALL be tested for the facial portrait region and for at least one printed identity attribute.
[EVA-MTC-14e]	Where the TOE verifies a security feature that can overlap the manipulated region, partial document projection (IAI D1.3) SHALL additionally be tested in transparent mode over a genuine document of an accepted type.
[EVA-MTC-14f]	Copy-move of segmented areas (IAI D1.4) SHALL be tested.
[EVA-MTC-14g]	Fully generated ID documents (IAI D1.5) SHALL be tested.

Table 5.9 Requirements on minimum test coverage for ID document attacks

Note to ►EVA-MTC-14: ID document injection attacks are only relevant where the document is authenticated visually through the video channel. Where the TOE authenticates the document cryptographically, e.g. by reading the chip via NFC with passive and active authentication or by comparison against an authoritative register, and this verification cannot be reproduced through the established IAM, the corresponding tests MAY be excluded following ►EVA-MTC-01.

Note to ►EVA-MTC-14a: The cap of 3 document types limits the number of test combinations when the TOE accepts many ID document types. The laboratory selects the worst case for the TOE, i.e. the types it assesses as most promising to fake, for example those with weaker or fewer security features or with layouts that are easier to reconstruct, and justifies the selection based on the pre-evaluation findings (see ►INI-DOC-03c). Where the TOE accepts fewer than 3 ID document types, all accepted ID document are tested, so a TOE that accepts only 2 types is tested with both and a TOE that accepts a single type only with that type.

Note to ►EVA-MTC-14d: The facial portrait of an ID document is a biometric reference. Manipulating it is equivalent to the face manipulation attacks against the live biometric channel, so the same instruments and coverage apply, projected into the document instead of the live capture.

5.4.7 Minimum Test Coverage for 3D Rendered Faces

Nr.	Requirement
[EVA-MTC-15]	The evaluation laboratory SHALL test the TOE against 3D rendered face instruments (IAI F1.5) using at least 1 distinct rendering pipeline.

Table 5.10 Requirements on minimum test coverage for 3D rendered faces

5.4.8 Minimum Test Coverage for Fully Generated Faces

Nr.	Requirement
[EVA-MTC-16]	For TOE that can be attacked with a synthetic identity that is not bound to a genuine reference using an authoritative source, the evaluation laboratory SHALL test the TOE against fully generated face instruments (IAI F1.6) using at least 1 model.

Table 5.11 Requirements on minimum test coverage for fully generated faces

5.5 Expected Result of IAD Evaluation

Nr.	Requirement
[EVA-RES-01]	As described by ▶Section 5.2 each Injection Attack Instrument SHALL be correctly classified within the given tolerance of the defined schema or must be excluded formally to be injectable. If any IAM and IAI combination is wrongly classified at least three times as bona fide, the evaluation can not pass at the targeted evaluation level without remediation (see ▶EVA-MET-06 and ▶EVA-MET-07).
[EVA-RES-02]	The resilience of the system evaluated on a test system where the IAI was directly injected, bypassing the need of an IAM that works on the real TOE, MAY be stated by the testing laboratory. This can increase the security assurance on the system that the system is resilient to detecting any IAI even when a zero-day exploit later reveals an unexpected IAM.

Table 5.12 Requirements on results

5.6 Evaluation Report

Nr.	Requirement
[REQ-REP-01]	The evaluation report SHALL specify test conditions and the environment used.
[REQ-REP-02]	The evaluation report SHALL give detailed overview that all injection methods have been covered by performed tests.
[REQ-REP-03]	If an injection method was not tested, the evaluation report SHALL state a formal explanation as to why this method is not relevant or can not be realized.
[REQ-REP-04]	The evaluation report SHALL give detailed overview that all injection instruments have been covered by performed tests.
[REQ-REP-05]	If an injection instrument was not tested, the evaluation report SHALL state a formal explanation as to why this instrument is not relevant or can not be realized.
[REQ-REP-06]	The evaluation report SHALL document which specific models, tools and configurations were used for each test case.

Table 5.13 Requirements on the evaluation report

Appendix A Relevant Requirement Catalogues

A.1 BSI TR-03147: Requirement catalogue for identification procedures

No.	Requirement
[TR03147-A2.1]	Video/information manipulations of biometric data of the person to be identified are detected
[TR03147-A2.2]	Manipulation of information transmitted from the ID document is detected
[TR03147-A2.5]	Live transmission of all data is guaranteed.
[TR03147-A2.6]	An exchange of the presented ID document or the person to be identified during the check is detected

Table A.1 Relevant requirements from BSI TR-03147.

A.2 ETSI TS 119 461

No.	Requirement
[VAL-8.3.2-04X]	If the digital identity document is required to be read from a chip embedded in a physical identity document, the identity proofing process shall protect against injection into the process, by the applicant or an external attacker, of a copy of a digital identity document that has previously been obtained and stored by the attacker.
[VAL-8.3.3-02X]	If a physical identity document is used as evidence in a remote identity proofing process, the process shall ensure that the applicant has the document in hand and presents the document in real-time in front of a camera.
[VAL-8.3.3-05X]	If the physical identity document is used in a remote identity proofing process, the process shall ensure that the video stream and any images captured are transmitted to an environment controlled by the actor responsible for the identity proofing process in a manner that ensures authenticity, integrity, and confidentiality of the video stream and images.
[VAL-8.3.3-05A]	If the physical identity document is used in a remote identity proofing process, the process shall protect against injection into the process, by the applicant or an external attacker, of a previously recorded or artificially generated video stream.
[VAL-8.4.2-02A]	The video capture process shall happen at the time of the identity proofing.
[VAL-8.4.2-03X]	The video stream capture shall apply means to detect artificially generated or manipulated face appearance.
[VAL-8.4.2-04]	If the video stream is captured on the applicant's device, the identity proofing process shall ensure that the video stream is transmitted to an environment controlled by the actor responsible for the identity proofing process in a manner that ensures authenticity, integrity, and confidentiality of the video stream.
[VAL-8.4.2-04A]	The identity proofing process shall apply biometric injection attack prevention and detection means to ensure that neither the applicant nor an external attacker can undetectably inject into the process a previously recorded or artificially generated video stream
[VAL-8.4.2-04B]	If the identity proofing targets Baseline LoIP, the biometric injection attack detection means shall be tested by an accredited laboratory according to TS 18099 ►CEN/TS 18099 level substantial (level 2) at the latest before the end of 2026.
[VAL-8.4.2-04C]	If the identity proofing targets Extended LoIP, the biometric injection attack detection means shall be tested by an accredited laboratory according to TS 18099 ►CEN/TS 18099 level high (level 3) at the latest before the end of 2026.
[VAL-8.4.2-04D]	Evaluation of biometric injection detection means by an accredited laboratory according to TS 18099 ►CEN/TS 18099 shall be repeated at least every second year.

Table A.2 Relevant requirements from ETSI TS 119 461.

Appendix B Possible Additional IAM

In this appendix methods are listed. These are not yet verified by the authors and therefore out of scope of the document. These can be added in future versions of this document when they are determined to be viable.

B.1 Unverified Injection Attack Methods

IAM-Nr.	Attack Method	Description
1.	Software-based injection methods	
1.5	Mobile App as Virtual Camera	Userspace application installed on mobile that registers as a system-wide camera source. Availability is OS-version dependent.
1.6	Memory-Corruption Frame Injection	Exploitation of a memory-corruption vulnerability (e.g. buffer overflow) in the TOE application to overwrite the decoded camera/frame buffer in memory with attacker-controlled frames. TOE-specific (requires an exploitable vulnerability) and is generically dominated by methods 1.x/4.x.
2.	Hardware-based injection methods	
2.2	USB Video Class - based injection	USB device that poses as legitimate video source to a mobile OS, e.g. via USB OTG together with a custom ROM / modified HAL to expose the external device as a camera source. Conditional on the device exposing external UVC cameras to applications, hence OS- and device-dependent.
2.3	Development Board as mobile	Use a (possibly uncertified) development board with controllable camera interface
2.4	Modification of trusted device	Physical replacement of camera on mobile with device that sends via MIPI CSI-2 but with controllable video source
2.5	Hardware MITM - based injection	Physical interception with device that uses original camera of mobile but replaced video data
2.6	HDMI to MIPI CSI-2 adapter	Use an HDMI to MIPI CSI-2 adapter as input to a mobile camera. May need adjustment of the mobile OS to recognize the hardware by adding respective drivers for example

Table B.1 IAM that need to be verified via defined projects

Appendix C Attack Rating Methodology

This appendix describes the attack rating methodology used to produce the minimal attack rating tables in ▶Appendix D and ▶Appendix E. The methodology is based on ▶CEN/TS 18099 and provides a structured way to estimate the attack potential required for each injection attack method (IAM) and injection attack instrument (IAI).

C.1 Identification and Exploitation Phases

The attack rating methodology of ▶CEN/TS 18099 determines the attack potential by estimating the effort, expertise, access, equipment and information needed to initially realize the attack and to subsequently exploit it for various identities. For this purpose the rating is separated into the two phases, identification and exploitation.

C.1.1 Identification Phase

The identification phase covers the effort to determine whether an attack method is viable and to implement it for a given TOE from the attacker's perspective. Testing laboratories can have elevated access to the system to save time in the implementation of specific attacks, but the estimations must still be based on the attacker's perspective (e.g. accounting for code deobfuscation even if the laboratory has full source code access). If public scripts and tools are generally available for the given method, they can be used and reduce the required time effort and expertise. If the time effort requires development of straightforward scripts that can be generated from large language models, the time effort and expertise for this task is reduced. It is expected that if a person is an expert in a field, they already have knowledge of all the basics and access to basic frameworks related to the field, even if not publicly available, and only need to apply their expertise to adapt to the specific TOE.

C.1.2 Exploitation Phase

The exploitation phase assumes that knowledge and developed tools from the identification phase are already available. This phase rates the effort to carry out the attack once fully prepared but accounting for identity specific tasks that need to be performed, e.g. training an identity-trained face swapping model.

C.2 Attack Potential Levels

The total weight of an attack rating is the sum of its identification and exploitation weights, combined as described in ▶Section C.4. This total weight maps to a named attack potential level according to ▶Table C.1.

Total Weight	Attack Potential Level
0 - 9	No rating
10 - 19	Basic
20 - 29	Enhanced-Basic
30 - 39	Moderate
40 and above	High

Table C.1 Mapping of the total attack rating weight to the attack potential level.

The attack potential levels Enhanced-Basic, Moderate and High correspond to the evaluation levels *normal*, *substantial* and *high* respectively, as shown in ▶Table 1.2.

C.3 Interpreting the Ratings

The ratings given in this document represent minimum values. Depending on the specific characteristics of the TOE, the actual attack potential required may be higher. Evaluators must therefore determine the concrete attack potential for each attack vector individually on the specific TOE under test. Based on this assessment, it can then be determined whether a given attack vector is relevant for the desired evaluation level as defined by the applicable certification scheme.

C.4 Combining Method and Instrument Ratings

When combining the ratings for an injection method and an instrument, the weights of individual criteria do not add linearly. Instead, the resulting combined interval must first be determined (e.g. the total time effort across both), and the corresponding weight then looked up from that combined interval. For example, if a specific IAM takes < 1 day (weight 1) and an IAI takes < 7 days (weight 3), the combined time effort may still fall within < 7 days (weight 3) or extend to < 25 days (weight 6), neither of which equals the sum of the individual weights (4).

C.5 Common Assumptions

The following criteria are estimated to be common across all attack ratings in this document when considering remote identity proofing solutions (for both the identification and exploitation phase) and are automatically included in the weight calculation, unless explicitly stated otherwise. Specific targets evaluated by a laboratory may deviate from these assumptions, which could result in a higher rating that must be accounted for.

Criteria	Interval	Weight	Rationale
Knowledge of product	Public	0	We assume that real-world attackers do not get access to restricted information about the TOE and their attack implementations are based on publicly obtainable knowledge.
Equipment	Standard	0	Most attacks only require standard hardware that is easily available in the market, e.g. mobile phones, desktop PCs with consumer GPUs.
Access to TOE	Easy	0	We assume that the standard TOE that is being targeted in this scenario is easily accessible.
Access to biometric characteristics	Easy	0	Most attacks only require a single image of the target, unless otherwise stated.
Degree of scrutiny	None	0	We assume that the TOE is unsupervised.

Table C.2 Common assumptions for attack ratings

C.6 Role of Optimization Aspects

The time effort and expertise values given for each injection attack method and instrument are estimated based on the steps described in their respective identification and exploitation phases. Optimization aspects listed for each attack are not included in the base rating, as their necessity and effort depend on the specific TOE. If optimization steps are required to successfully carry out an attack against a specific TOE, the resulting additional effort must be factored into the overall rating accordingly.

Appendix D Guidance on Injection Methods

This appendix provides guidance on implementing injection methods (IAM) as described in ▶Table 3.1. These methods describe how to deliver prepared attack payloads to the target system, independent of the payload content. The applicability of each method varies by application type (Desktop, Mobile, Web). These examples reflect publicly known methods as of 2026 and are a minimum baseline. Evaluators are expected to research and apply newer or stronger methods where available. Concrete tool examples for each method are maintained in a separate laboratory annex that is provided to evaluation laboratories on request and is not part of the published guidance.

D.1 Software-Based Injection Methods

D.1.1 Virtual Camera

Virtual camera devices that register as a video source, either as user-space applications using OS APIs/frameworks or as kernel modules/drivers that are treated by the OS as hardware.

D.1.1.1 Identification Phase

- Install a virtual camera, refer to ▶Carta for further details.
- Use software or write a script to feed video stream to virtual camera module, e.g. using a scripting language together with a video processing tool as feed into a virtual video device kernel module.
- Mirror live webcam feed into virtual camera to test method on the target web application. Refer to optimization aspects in case the mirroring technique gets detected.

D.1.1.2 Exploitation Phase

- Open browser and navigate to the target website or start the application on desktop and start the authentication flow.
- When prompted by the browser or application select virtual camera as video input source.
- Run authentication flow on service while feeding IAI into the virtual camera.

D.1.1.3 Optimization Aspects

- Use a monitoring script on genuine and virtual camera and log calls from browser to webcam during injection attack, e.g. using a system call tracer on Linux. Determine which functions are triggered by website and assess their relevance (e.g. camera focus adjustments).
- Try IAM in different browsers (e.g. a Chromium-based and a Firefox-based browser, ...), as they have slightly different implementations to access the camera and therefore the IAD module can behave differently.
- Ensure virtual camera does not have any obvious labels, e.g. device name should not be “Virtual Camera”.
- Place virtual webcam at first index position in video devices, alternatively remove all physical webcams from device and feed input stream to virtual camera via network socket.
- Try the attack on different operating systems, as IAD behavior may differ across platforms.
- Extend the virtual camera software/kernel module to simulate existence / responses of user controls that might be checked by applications. Patch responses to capability flags or similar to match a real camera. Existence of the virtual video device kernel module may also need to be hidden, e.g. by building it under a different name and renaming reported driver names.
- Match pixel format and resolution capabilities of a common real camera model. Virtual camera exposing only a single format or resolution could be detected.
- Ensure frame delivery timing is comparable to a real camera.
- Sandbox the application to restrict its view of the OS environment, preventing it from detecting the virtual camera through system-level inspection (e.g. loaded kernel modules, device tree, ...).

D.1.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		3 + 0 = 3		
Min. Attack Level		No rating		
Applicability				
TOE application type	Desktop, Web			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files and Live streams			

Table D.1 Attack rating and applicability for virtual camera method

D.1.2 Kernel-level Modification of Camera Driver

Modify existing camera drivers or implement custom kernel-level camera modules that intercept and replace camera data at the driver level, before it reaches user-space applications. The modified driver must continue to respond plausibly to control requests issued by user-space (e.g. V4L2 `ioctl`s for capability enumeration, format negotiation, and exposure / focus / white-balance controls) so that capability probing by the TOE does not reveal the substitution.

D.1.2.1 Identification Phase

- If the TOE supports it, use an operating system where kernel-level driver modifications are practical, e.g. a Linux distribution where camera driver source code is openly available and out-of-tree kernel modules can be built and loaded without restrictions.
- Obtain the camera driver source code (e.g. the UVC driver on Linux) and locate the point where complete frames are handed to the OS video subsystem. Modify the driver to replace frame buffer contents with injected data sourced from a file or live stream.
- Write scripts to convert the IAI into the pixel format and encoding expected by the driver. Build and load the modified driver in place of the original and verify that injected frames are delivered correctly.

D.1.2.2 Exploitation Phase

- Load the modified camera driver and start the scripts that decode and feed the prepared IAI into the driver.
- Start the target application and run the authentication flow. The application captures frames through the standard video capture API, which delivers the injected content.

D.1.2.3 Optimization Aspects

- Ensure frame delivery timing and response behavior for control requests (e.g. focus, exposure, white balance) remain consistent with the original driver to avoid detection through timing analysis or capability probing.
- If the operating system enforces driver signing, bypass or attempt to satisfy this requirement (e.g. enabling test-signing mode on Windows or enrolling a custom signing key on Linux).

D.1.2.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		7 + 0 = 7		
Min. Attack Level		No rating		

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Applicability				
TOE application type	Desktop, Web			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files and Live streams			

Table D.2 Attack rating and applicability for kernel-level modification of camera driver method

D.1.3 Emulated System

Run the target application in an emulated or virtualized environment where camera input is fully controlled.

D.1.3.1 Identification Phase

- On a desktop, set up emulator software. Determine the minimum Android version required by the target application and select a matching emulator image.
- Use a video file or a virtual camera as camera source for the emulator camera. Use a live webcam feed when testing initially with an application to see if the emulator gets past initial checks.
- Determine appropriate settings with respect to the TOE. Off-the-shelf emulators are often restricted in what they accept as source. Adjust the stream if necessary, e.g. in a video processing pipeline, to provide the optimal resolution.
- Alternatively, AOSP can be modified to define an emulator image where a camera feed can be delivered in any desired video resolution. See the respective optimization aspect.
- Refer to Carta et al. ▶Carta for an elaborated approach, details and further references.

D.1.3.2 Exploitation Phase

- Prepare IAI as source for the video feed of the emulator and configure emulator accordingly.
- Start emulator and run script to attempt emulator detection evasion.
- Run authentication flow on service with IAI.

D.1.3.3 Optimization Aspects

- Refer to ▶Section D.5.1 for root detection evasion techniques.
- Refer to ▶Section D.5.2 for emulator detection evasion techniques.
- Refer to ▶Section D.5.4 for platform integrity attestation evasion techniques.
- Refer to ▶Section D.5.5 to spoof gyroscope and other sensor data if relevant.
- To bypass emulator camera limitations, refer to ▶Section D.1.4.

D.1.3.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				
TOE application type	Mobile			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files and Live streams			

Table D.3 Attack rating and applicability for emulated system method

D.1.4 Customized OS / Runtime Environment

Build a custom OS image with a modified camera subsystem, or with patched framework / managed-runtime components above the hardware abstraction layer, so that the system-wide camera source or its framework-level API delivers arbitrary video input to the TOE.

D.1.4.1 Identification Phase

- Obtain OS source tree matching targeted version of application, e.g. AOSP for targeted Android version, and set up a system to build the base image.
- Modify the camera HAL implementation to read frames from a file, pipe, or network socket instead of from a real camera sensor.
- Alternatively or in addition to HAL modification, framework JARs or managed-runtime class implementations may be patched within the same OS build to substitute frames or spoof checks at the framework/Java layer above the HAL.
- Configure the modified HAL to report realistic camera properties (sensor size, supported resolutions, auto-focus capabilities, ...) matching a common physical device.
- Boot the custom AOSP image on an emulator or flash to a physical device.
- Test that the target application recognizes the modified camera HAL as a legitimate hardware camera and receives frames in a genuine attempt.

D.1.4.2 Exploitation Phase

- Using the device with the custom AOSP, feed an IAI to the modified camera HAL via the established route (file, pipe, or network socket).
- Run authentication flow on service with IAI.

D.1.4.3 Optimization Aspects

- Spoof camera characteristics (e.g. supported formats, sensor metadata, ...), e.g. on the OS level or via hooking (refer to ▶Section D.4.2), to misrepresent the capture device to the TOE.
- Ensure camera metadata (timestamps, frame intervals, ...) matches real hardware behavior.
- Spoof build properties of the self-compiled OS to match those from a real certified device.
- Refer to ▶Section D.5.1 for root detection evasion techniques if applicable.
- Refer to ▶Section D.5.2 for emulator evasion techniques when running in emulated environment.
- Refer to ▶Section D.5.4 for platform integrity attestation evasion techniques.
- Refer to ▶Section D.5.5 to spoof gyroscope and other sensor data if relevant.

D.1.4.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 25 days	6	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		11 + 0 = 11		
Min. Attack Level		Basic		
Applicability				
TOE application type	Mobile			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files and Live streams			

Table D.4 Attack rating and applicability for custom OS with modified camera subsystem method

D.2 Hardware-Based Injection Methods

D.2.1 USB Video Class-based Injection

Use a hardware device that presents itself as a legitimate USB video camera using the standard UVC protocol.

D.2.1.1 Identification Phase

- Acquire a USB Video Class (UVC) compatible capture card. These devices register as standard USB webcams in the OS.
- Connect a video source (e.g. second desktop) to the HDMI input of the capture card.
- Verify that the capture card is enumerated as a standard webcam device by the OS and that the target application accepts it as camera input.

D.2.1.2 Exploitation Phase

- Play IAI on the source device connected to the capture card HDMI input.
- Select the capture card as camera source in the target application.
- Run authentication flow on service with IAI.

D.2.1.3 Optimization Aspects

- Attempt different capture cards that vary in reported webcam device labels and specifications.
- If possible, match output resolution and frame rate of the source device to common webcam specifications.
- If possible, use capture cards that support UVC controls (e.g. brightness, contrast) to respond to application queries.

D.2.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		3 + 0 = 3		
Min. Attack Level		No rating		
Applicability				
TOE application type	Desktop, Web			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files and Live streams			

Table D.5 Attack rating and applicability for USB Video Class-based injection method

D.2.2 In Discussion: Hardware Injection over MIPI CSI-2 of Mobile

Publications report the replacement of the camera module of a mobile phone by attaching a custom device on the MIPI CSI-2 port to inject arbitrary video data directly at the hardware interface. Refer to ►Carta for more references. As we have not yet replicated this attack it is not presented here in detail. If it can be demonstrably replicated on relevant devices it will be necessary to also test for such an IAM.

D.2.2.1 Feasibility Considerations

- The MIPI CSI-2 interface consists of two independent parts: high-speed CSI-2 data lanes carrying pixel data, and an I2C control bus over which the HAL sends initialization sequences and register reads/writes to the sensor IC. A replacement device must handle both correctly.
- During camera open, the HAL sends device-specific I2C register sequences to configure the sensor (exposure, gain, pixel format, resolution). The replacement device must respond plausibly to these.

- CSI-2 lane count, data rate, and pixel format are SoC- and device-specific. A generic CSI-2 source is unlikely to work across different phone models without per-device characterization.
- Required hardware includes an FPGA or a dedicated CSI-2 transmitter board capable of generating compliant CSI-2 signals, plus physical disassembly of the target device to access the camera connector.
- Single-board computers running Android expose their CSI-2 camera connector by design and can serve as a development and validation platform for the attack hardware before attempting it on a consumer device requiring disassembly.

D.3 Network-Based Injection Methods

D.3.1 Man-in-the-Middle Attack

Intercept network communication between client and server, replacing legitimate biometric data with prepared attack payload.

D.3.1.1 Identification Phase

- Set up an MITM proxy on a desktop and configure the target device to route traffic through it.
- Install the proxy's root CA certificate on the target device to intercept TLS-encrypted traffic.
- Perform a legitimate authentication session while capturing all network traffic. Analyze the API endpoints, request/response formats, and the structure of transmitted biometric data (e.g. video frames, encoded streams, metadata).
- Identify which requests carry biometric data or relevant metadata and also determine the encoding, compression, and any integrity mechanisms (e.g. checksums, signatures, sequence numbers, ...) applied to the payload.
- Configure MITM proxy with a script that intercepts outgoing biometric data and replaces the payload with IAI data matching the identified format. Also, if possible, match and replace metadata if it is (partially) related to the sent biometric data.

D.3.1.2 Exploitation Phase

- Run authentication flow on service while passing traffic through the proxy.
- Replace biometric data in transit with IAI using the proxy.

D.3.1.3 Optimization Aspects

- Refer to ▶Section D.5.1 for root detection evasion techniques when installing custom CA certificates on mobile devices.
- Refer to ▶Section D.5.6 for bypassing SSL certificate pinning techniques.
- Preserve original request metadata (timestamps, session tokens, content lengths) to avoid server-side validation failures.
- Replay timing patterns from recorded legitimate sessions to match expected frame rates and inter-request intervals.
- Avoid configuring an explicit proxy in the device's network settings, as applications could detect explicit proxy configurations and may refuse connections or alter behavior. Instead, perform transparent MITM interception at the network level using a router that can reroute traffic to the proxy (e.g. using a router with custom firmware), making the interception invisible to the application.
- Combine with API hooking (refer to ▶Section D.4.2) if the application performs client-side checks on frames, e.g. to ensure that frames analyzed locally within the app are consistent with those sent to the server. In such cases, API hooking can be used to also replace the frames on the client side or to bypass the consistency check.

D.3.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		7 + 0 = 7		
Min. Attack Level		No rating		
Applicability				
TOE application type	Desktop, Mobile, Web			
TOE processing data	Server-side			
TOE data input	Image/video files and Live streams			

Table D.6 Attack rating and applicability for man in the middle attack method

D.4 Application-Level Injection Methods

D.4.1 File Replacement

If the application persists captured biometric data to the filesystem before transmission, intercept and replace the file before it is transferred.

D.4.1.1 Identification Phase

- Determine whether the application persists captured data locally before evaluating/transmitting it, or whether it evaluates or streams data directly.
- If data is stored locally, identify the storage location (e.g. internal app directory, external/shared storage, or a cache directory), file format, naming convention, and any integrity metadata (hashes, timestamps, EXIF data) associated with the captured files by observing the file system or reverse engineering the app.
- Optionally, observe network traffic between the application and its backend server (e.g. using an MITM proxy, refer to ►Section D.3.1) to identify the expected file format, encoding, and metadata of the transmitted data.
- If the data is stored in the application's private internal directory, root the device to gain read and write access.
- Test replacing a recorded file with a modified copy and observe whether the application detects the modification locally. Perform this step in an offline setting (e.g. by blocking network access or redirecting traffic to a local mock server) to first resolve all client-side detection mechanisms before attempting the attack against the live backend.

D.4.1.2 Exploitation Phase

- Prepare IAI as video file either by preparing it before the session or by recording it during the session on a desktop.
- Start authentication flow and let the application capture the biometric data.
- Replace the captured file(s) in the application's storage directory with the prepared IAI file before the application processes or uploads them.

D.4.1.3 Optimization Aspects

- If applicable, refer to ►Section D.5.1 for root detection evasion techniques.
- Monitor the file system to automate detection of newly written files and trigger immediate replacement. Note that the timing window between the app writing the file and reading/uploading it may be very narrow.
- If the timing window is too tight for file system monitoring, API hooking (refer to ►Section D.4.2) can be attempted to intercept file I/O or upload calls and to delay the upload to gain time for the replacement.

- As an alternative delivery technique that avoids the timing race entirely, the storage path can be attempted to be backed by a virtual filesystem (e.g. FUSE on Linux) instead of physical storage. The application's writes are accepted by the userspace filesystem and reads return the IAI directly, without a separate replacement step. On Android, mounting a virtual filesystem over the application's private storage requires root.
- Match file metadata (timestamps, file size headers, EXIF data) of the replacement file to the original to attempt to avoid server-side validation failures.

D.4.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				
TOE application type	Desktop, Mobile, Web			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files			

Table D.7 Attack rating and applicability for file replacement method

D.4.2 API Hooking

Hook camera or data processing APIs within the application so that genuine biometric data is replaced with an IAI before the application processes or transmits it. Hooking is most commonly done by instrumenting the application while it is running (e.g. with a dynamic-instrumentation framework), but the same effect can be achieved by modifying the application's installed files directly, so that the modified version does the substitution on its own.

D.4.2.1 Identification Phase

- Prepare the device for API hooking with a dynamic-instrumentation framework (refer to ▶Carta for further references). This can for example be done either by rooting the device and running the framework's server component, or by repackaging the application with the framework's gadget embedded, which trades the need for root access by app repackaging.
- On Android, framework-level hooking via Zygote-injected module frameworks is an additional option that hooks at the Java framework layer rather than instrumenting individual app processes. This leaves the APK untouched but requires root access or a customized OS.
- The same dynamic instrumentation outcome can be reached without a hooking framework, by directly manipulating the running process's memory or injecting custom code into it. These techniques are more effort but avoid framework-specific runtime signatures. They are mainly relevant when the TOE has detections that target the instrumentation framework and cannot be easily spoofed.
- As an alternative to runtime instrumentation, the application can be modified directly on disk. On Android this means unpacking the APK, editing smali or native code, repacking and re-signing it. On desktop the executable is patched, on web the loaded JavaScript is modified. This avoids needing an instrumentation framework at runtime but requires more reverse engineering effort up front. On platforms where the application's identity is verified by the server (e.g. via platform integrity attestation), the modified application triggers the same checks as a repackaged one. Refer to ▶Section D.5.3 and ▶Section D.5.4 for repackaging and platform integrity check evasion respectively.
- Attempt hooking common camera APIs using publicly available hooking scripts.
- If generic scripts are insufficient, reverse engineer the application to determine how it fetches camera frames and write a custom injection script to hook the relevant functions. If code obfuscation is present, deobfuscation must be performed first.

- Verify the hooking mechanism by first injecting genuine recorded material and confirming the application processes it correctly. Depending on the TOE, either load prepared video or image files from the device's storage, or continuously stream frames via a network socket if the application requires real-time input.

D.4.2.2 Exploitation Phase

- Start the hooking framework and attach the injection script to the target application process.
- Run the authentication flow in the application using IAI frames instead of real camera data.

D.4.2.3 Optimization Aspects

- Refer to ▶Section D.5.1 for root detection evasion techniques.
- If applicable, refer to ▶Section D.5.3 for repackaging evasion and to ▶Section D.5.4 for platform integrity attestation evasion.
- Determine if additional metadata related to the replaced frames is transferred to the backend during the authentication flow (e.g. by using an MITM proxy, refer to ▶Section D.3.1) and patch these accordingly.

D.4.2.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		8 + 0 = 8		
Min. Attack Level		No rating		
Applicability				
TOE application type	Desktop, Mobile, Web			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files and Live streams			

Table D.8 Attack rating and applicability for API hooking method

D.4.3 Modified / Custom Client

Reverse-engineer the client application and build a custom client that replicates the server communication protocol but allows full control over biometric data, inherently bypassing all client-side protections.

D.4.3.1 Identification Phase

- This method requires significant effort and should only be considered when simpler attack vectors (e.g. MITM attack on backend communication ▶Section D.3.1, file replacement ▶Section D.4.1, or API hooking (▶Section D.4.2)) have been ruled out or proven insufficient due to strong client-side protections.
- Reverse engineer the client application to understand the communication protocol with the backend, using appropriate decompilation or disassembly tools for the target platform and framework (e.g. native, web, or cross-platform). Deobfuscating the code might be necessary.
- If static analysis alone is insufficient to fully understand the protocol, capture and analyze network traffic during legitimate sessions using an MITM proxy (refer to ▶Section D.3.1) to document API endpoints, authentication flows, request/response schemas, and session management.
- Identify client-side integrity or attestation mechanisms (e.g. device binding tokens, app signatures, challenge-response protocols) that the server expects, and replicate or bypass them in the custom client.
- Determine how biometric data is encoded and transmitted (e.g. raw frames, compressed video, extracted feature vectors) and whether any client-side preprocessing (cropping, resolution scaling, format conversion) is applied before upload.
- Identify any anti-replay mechanisms such as server-issued nonces, timestamp validation windows, or sequence numbering in the protocol.

- Implement a custom client that replicates the communication protocol, including authentication handshakes, session tokens, and expected metadata fields. Client-side liveness checks or detection mechanisms are inherently bypassed by not implementing them.
- Validate the custom client against the live backend using legitimate biometric data before attempting with IAI.

D.4.3.2 Exploitation Phase

Run the authentication flow using the custom client with an IAI.

D.4.3.3 Optimization Aspects

- Mimic realistic request timing and intervals observed during legitimate sessions to avoid server-side anomaly detection.
- Spoof TLS fingerprints to match the original client's TLS stack.
- If WebSocket or persistent connections are used, ensure the custom client maintains the same connection lifecycle and heartbeat patterns.

D.4.3.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	> 25 days	10	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		15 + 0 = 15		
Min. Attack Level		Basic		
Applicability				
TOE application type	Desktop, Mobile, Web			
TOE processing data	Server-side			
TOE data input	Image/video files and Live streams			

Table D.9 Attack rating and applicability for modified / custom client method

D.4.4 System Library / Dependency Substitution

Substitute dynamically linked libraries that the application loads at runtime (e.g. TLS or codec libraries) with attacker-controlled versions. The application loads the substituted code through the normal dynamic linker path. The application binary itself is not modified, so app-internal integrity checks that hash only the bundled application files are not triggered.

D.4.4.1 Identification Phase

- Determine which dynamically linked libraries the application uses for video data acquisition, biometric data processing, or transmission. Typical candidates are system TLS libraries (e.g. `libssl`, `libcrypto`), HTTP / networking libraries (e.g. `libcurl`), and media / codec libraries (e.g. `libavcodec`).
- Distinguish libraries the application bundles in its own private directory from those it loads from the system. Integrity checks for the two categories are usually performed differently.
- For each relevant library, identify the function calls the application performs and the corresponding interception points.
- Build a replacement library that exposes the same ABI as the original and forwards unmodified calls to the genuine implementation while intercepting the relevant subset. Verify that the application loads and uses the replacement, e.g. via logging from the replacement library or by first injecting genuine recorded material and confirming the application processes it correctly.
- Install the replacement library so that the application's dynamic linker resolves it instead of the original. Possible routes are:

- Overwriting the system copy. This requires write access to the system library path. On desktop this typically requires root, on Android a rooted device with writable system partition.
 - Manipulating the dynamic linker search path so that the replacement is preferred (e.g. via `LD_LIBRARY_PATH` or `LD_PRELOAD` on desktop).
 - Substituting a library inside a directory that the linker prefers over the system copy.
- Test if the replaced library is being used in a genuine attempt.

D.4.4.2 Exploitation Phase

Run the authentication flow with the application using the replaced libraries with an IAI.

D.4.4.3 Optimization Aspects

- Forward all calls and side effects that are not part of the substitution path to the genuine library to minimize observable behavioral differences.
- If the application performs integrity checks on libraries inside its own bundle, route the substitution through the linker search path or by overwriting the system copy rather than by modifying the bundled file.
- Combine with API hooking (refer to ▶Section D.4.2) when finer-grained control inside the replacement library is needed, e.g. to conditionally substitute only specific calls based on call-site information.
- If the operating system enforces library signature checks or restricts `LD_PRELOAD`, choose a substitution route that is not subject to those restrictions, or address them as part of the identification phase.
- Refer to ▶Section D.5.1 if system-partition writes on mobile are required for the substitution.

D.4.4.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		8 + 0 = 8		
Min. Attack Level		No rating		
Applicability				
TOE application type	Desktop, Mobile, Web			
TOE processing data	Client-side, Server-side			
TOE data input	Image/video files and Live streams			

Table D.10 Attack rating and applicability for system library / dependency substitution method

D.5 Supplementary Optimization Techniques

Below, supplementary techniques that may be considered when attempting various IAM are listed. They may help to bypass certain aspects of a defense mechanism and therefore enable the IAM to be effective. In terms of the overall attack potential, they add in most cases to the attack rating in terms of required time, expertise, and possibly window of opportunity. The same rules for combining weights as described in ▶Appendix C apply. Where multiple supplementary techniques depend on each other, e.g. app repackaging detection evasion may trigger the need for platform integrity attestation evasion, the evaluator should account for the combined effort of the entire chain.

D.5.1 Root Detection Evasion

Root detection evasion is relevant for all mobile attack methods that require elevated privileges on the target device, e.g. to perform runtime API hooking or to modify system build properties.

D.5.1.1 Techniques

The concrete bypass techniques are maintained in the laboratory annex available on request.

D.5.1.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				
TOE application type	Mobile			

Table D.11 Attack rating and applicability for root detection evasion

D.5.2 Emulator Detection Evasion

When running mobile applications inside an emulated environment, it may be relevant to attempt evasion of emulator detection mechanisms.

D.5.2.1 Techniques

The concrete bypass techniques are maintained in the laboratory annex available on request.

D.5.2.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				
TOE application type	Mobile			

Table D.12 Attack rating and applicability for emulator detection evasion

D.5.3 App Repackaging Detection Evasion

Applications may verify their own binary integrity at runtime by checking the APK signature or hashes of code and native libraries, independent of platform-level attestation. This is relevant whenever the APK has been modified, e.g. to inject an instrumentation gadget, remove SSL pinning, or patch out detection logic.

D.5.3.1 Techniques

The concrete bypass techniques are maintained in the laboratory annex available on request.

D.5.3.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
TOE application type	Mobile			

Table D.13 Attack rating and applicability for app repackaging detection evasion

D.5.4 Platform Integrity Attestation Evasion

Platform integrity attestation verifies that the application runs on a genuine, unmodified operating system on a vendor-certified device, and optionally that the application binary has not been repackaged or distributed outside official channels. The attestation is typically triggered by the application providing a nonce or request hash to the platform's integrity API. The platform services then collect integrity evidence about the device and application, and the platform vendor's server infrastructure evaluates this evidence and issues a signed attestation token containing verdicts on device integrity, app integrity, and request-binding data. The backend verifies or decrypts this token through the platform vendor's server API.

The difficulty of bypassing attestation depends on the implementation. In particular, whether attestation is verified by the backend, which verdicts the backend actually evaluates (e.g. device integrity only, or also app integrity and licensing), how strongly the verdict is bound to hardware-level signals, and whether attestation is performed only once or the session is bound to the attested device. Note that the attestation token may contain separate verdicts for device integrity and app integrity, and these may require different evasion strategies.

D.5.4.1 Techniques

The concrete bypass techniques are maintained in the laboratory annex available on request.

D.5.4.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< one day	3
Expertise	Expert	5	Proficient	2
Total Weight		8 + 5 = 13		
Min. Attack Level		Basic		
Applicability				
TOE application type	Mobile			

Table D.14 Attack rating and applicability for platform integrity attestation evasion

D.5.5 Spoofing of Mobile Phone Sensors (Gyroscope, etc.)

Some applications query device sensors especially to detect emulated environments or scripted interactions.

D.5.5.1 Techniques

The concrete bypass techniques are maintained in the laboratory annex available on request.

D.5.5.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				
TOE application type	Mobile			

Table D.15 Attack rating and applicability for spoofing of mobile phone sensors

D.5.6 Bypass SSL Pinning

SSL/TLS certificate pinning prevents the use of MITM proxies by validating that the server certificate matches a pinned certificate or public key embedded in the application.

D.5.6.1 Techniques

The concrete bypass techniques are maintained in the laboratory annex available on request.

D.5.6.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		3 + 0 = 3		
Min. Attack Level		No rating		
Applicability				
TOE application type	Mobile			

Table D.16 Attack rating and applicability for bypass SSL pinning

Appendix E Guidance on Injection Instruments

This appendix provides guidance on preparing IAs as described in ▶Section 3.6. For each attack instrument, this section describes the required source material and tools to generate the attack content. These examples serve as a foundational baseline reflecting public implementations at the date of the last change of this document. Evaluators are expected to actively research and incorporate more advanced or superior methodologies and tools to ensure the evaluation remains state-of-the-art. Concrete tool examples for each instrument are maintained in the same separate laboratory annex, provided to evaluation laboratories on request and not part of the published guidance.

E.1 Genuine Attacks

The replay and relay instruments below are described for the live face capture. They apply equally to a genuine ID document presented through the video stream, where a recording or live presentation of the document takes the place of the face. For documents they are only relevant where the document is authenticated visually through the video channel and not where it is verified cryptographically (see ▶EVA-MTC-10c, ▶EVA-MTC-10d and the conditions in ▶EVA-MTC-14). Relay of a document presentation is relevant where the TOE uses a document challenge-response, for example tilting the document to reveal security features.

E.1.1 Replay Attack

Setup software to feed pre-recorded video streams as camera input to an established injection method.

E.1.1.1 Identification Phase

- Set up software or write scripts to feed videos into format required for applicable IAM, e.g. using a scripting language and a video processing tool.
- If applicable, enable software to control when video starts and stops being streamed and to switch between multiple pre-recorded videos interactively.

E.1.1.2 Exploitation Phase

- Record or collect a video of a person looking into the camera, ideally performing generic responses similar to challenges in the application.
- Inject pre-recorded video using scripts/software and an established injection method.

E.1.1.3 Optimization Aspects

- Collect multiple videos of person with various generic movements and splice videos depending on challenge in application.
- Apply post-processing manipulations to mask splicing frames. Refer to ▶Section E.5.
- Adjust video properties (resolution, frame rate, compression) to match what the target application's camera would typically produce.

E.1.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Layperson	0	Layperson	0
Total Weight		1 + 0 = 1		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered			

Table E.1 Attack rating and applicability for replay attack using pre-recorded stream(s)

E.1.2 Relay Attack

Build a controlled application that relays TOE session events (e.g. challenge-response prompts) in real time to a separate endpoint where a person reacts to them, and inject the captured reaction as camera input via the established IAM. The person at the relay endpoint is typically an unwitting victim lured under a phishing pretext (e.g. believing they are registering with a different service using a malicious app).

E.1.2.1 Identification Phase

- Set up software or write scripts to record a person at the relay endpoint and to display instructions on actions to perform based on the TOE's relayed challenges.
- Automate a pipeline to extract challenge prompts from the TOE in real time and forward them to the relay endpoint's recording software. The challenges can be collected for example by parsing application logs or by screenrecording the application and parsing the capture in real-time.
- Stream the recording from the relay endpoint in real time to the established IAM in the required format, or deliver it as a recorded video file when the IAM requires file input.

E.1.2.2 Exploitation Phase

- Record a person as expected by the TOE (e.g. simulating a phishing scenario) using the developed software while performing authentication in a separate process. Provide instructions based on the application's challenges.
- Inject the recording stream or the recorded video using the established injection method.

E.1.2.3 Optimization Aspects

- Minimize end-to-end latency of the relay pipeline to ensure challenge responses are delivered within the application's expected time window.
- Ensure video quality and resolution of the relay stream match realistic camera output conditions as expected by the TOE.
- Apply post-processing to the relay stream to match expected camera characteristics. Refer to ►Section E.5.

E.1.2.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Layperson	0	Layperson	0
Total Weight		2 + 0 = 2		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Real-time			

Table E.2 Attack rating and applicability for relay attack

E.2 Face Synthesis and Manipulation Techniques

E.2.1 Identity-Trained Face Swapping

Train a face swapping model on images of a specific target identity to generate high-fidelity face swaps.

E.2.1.1 Identification Phase

- Select and configure a face swapping framework.
- Set up scripts to perform training according to framework and to handle post-processing on generated image or video.

- Evaluate swap quality with varying target identities: check biometric similarity to genuine target image, presence of visual artifacts, behavior in relevant challenge-response settings and temporal consistency.

E.2.1.2 Exploitation Phase

- Collect training data of target identity: images and/or videos from social media, public records, or purpose-recorded material. Quantity and diversity requirements depend on the framework (e.g. a few hundred images for a typical framework). Depending on the model, the attacker's face or a large image database of faces need also to be collected once.
- Train identity-specific model using the framework.
- If possible, export trained model to a faster format for inference.
- Generate swapped video either offline (pre-rendered) or in real-time if the trained model supports it.
- Inject the stream or the video using the established injection method.

E.2.1.3 Optimization Aspects

- Increase training data diversity (lighting, angles, expressions) to improve swap robustness across different session conditions.
- Apply post-processing (face enhancement, color correction) to reduce visible artifacts at face boundaries. Refer to ▶Section E.5.
- Refer to ▶Section E.5.4 for temporal optimizations.
- Test multiple face swapping frameworks, as swap quality varies significantly per identity and framework and deepfake detection systems tend to have problems generalizing across different frameworks.
- Combine with adversarial perturbations to evade deepfake detection systems.

E.2.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< three days	4
Expertise	Proficient	2	Proficient	2
Access to biometric characteristics	Moderate	4	Moderate	4
Total Weight		9 + 10 = 19		
Min. Attack Level		Basic		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (framework-dependent)			

Table E.3 Attack rating and applicability for identity-trained face swapping

E.2.2 One-Shot Face Swapping

Perform face swapping using a single reference image of the target identity, without requiring identity-specific model training.

E.2.2.1 Identification Phase

- Set up a one-shot face swapping tool.
- Prepare scripts to use the framework and to deliver it as IAI in real-time settings. If necessary, extend the framework for these purposes. Determine achievable resolution, frame rate, etc.
- Evaluate the swap quality with different target identities, reference images and lighting conditions to determine which reference produces the best biometric similarity, face image quality and visual coherence. Determine behavior in relevant challenge-response settings.

E.2.2.2 Exploitation Phase

- Obtain reference image of the target identity (e.g. from ID document, social media, or photograph).
- Start the face swapping tool with the selected reference image using a video or live face as driving input.
- Inject the stream or the video using the established injection method.

E.2.2.3 Optimization Aspects

- Apply post-processing (face enhancement, color correction) to reduce visible artifacts at face boundaries. Refer to ▶Section E.5.
- Refer to ▶Section E.5.4 for temporal optimizations.
- Test multiple one-shot frameworks, as swap quality varies significantly per identity and framework and deepfake detection systems tend to have problems generalizing across different frameworks.
- Combine with adversarial perturbations to evade deepfake detection systems.

E.2.2.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time			

Table E.4 Attack rating and applicability for one-shot face swapping

E.2.3 Single Image Animation

Generate a video from a single still photograph of the target identity using motion transfer from a driving video/webcam, or by a driving audio, or by animating the still with a text-prompted image-to-video model.

E.2.3.1 Identification Phase

- Set up an image animation framework.
- Prepare scripts to use framework and to deliver it as IAI in real-time settings if possible with expected resolution, framerate, pixel format, etc.
- If pre-rendered videos are viable, use video generation models with the given image to produce a generic response to given challenges.
- Evaluate quality with different target identities and reference images to determine which reference produces the best biometric similarity and visual coherence. Determine behavior in relevant challenge-response settings.

E.2.3.2 Exploitation Phase

- Obtain reference image of the target identity (e.g. from ID document, social media, or photograph).
- Drive the animation model using the attacker's webcam as motion source or using pre-recorded driving video.
- Inject the stream or the video using the established injection method.

E.2.3.3 Optimization Aspects

- Vary resolution of source images and determine best resolution and format for the image animation framework.

- Apply post-processing (face enhancement, color correction) to improve visual quality. Refer to ▶Section E.5.
- Refer to ▶Section E.5.4 for temporal optimizations.
- Combine with adversarial perturbations to evade deepfake detection systems.

E.2.3.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 0 = 4		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time			

Table E.5 Attack rating and applicability for single image animation

E.2.4 Video Reenactment

Transfer facial expressions and head movements from a driving source onto a target face in an existing video, either replacing the full head or only specific regions, e.g. the mouth while keeping the rest of the genuine video. Alternatively by using the video to train a model to generate a new video of the person with reenacted pose.

E.2.4.1 Identification Phase

- Set up a video reenactment framework based on driving audio or video.
- Prepare scripts to use the framework and to deliver it as IAI with expected resolution, frame rate, pixel format, etc.
- Evaluate quality with different target identities, reference videos and varied driving videos to determine which reference produces the best biometric similarity and visual coherence. Determine behavior in relevant challenge-response settings.
- Note: Even though multiple publications exist for this kind of technique, most seem to be closed source. The general feasibility of this instrument for testing laboratories needs to be assessed.

E.2.4.2 Exploitation Phase

- Obtain reference video of the target identity.
- Drive the reenactment using audio or video depending on the framework and the challenge of the TOE.
- Inject the stream or the video using the established injection method.

E.2.4.3 Optimization Aspects

- Vary resolution of videos and determine best resolution and format to operate on for used frameworks.
- Apply post-processing (face enhancement, color correction) to improve visual quality. Refer to ▶Section E.5.
- Refer to ▶Section E.5.4 for temporal optimizations.
- Combine with adversarial perturbations to evade deepfake detection systems.

E.2.4.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< one hour	0
Expertise	Proficient	2	Layperson	0

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Total Weight			5 + 0 = 5	
Min. Attack Level			No rating	
Applicability				
IAI real-time capability	Pre-rendered and Real-time (framework-dependent)			

Table E.6 Attack rating and applicability for video reenactment

E.2.5 3D Rendered Faces

Render the head of the target identity using 3D rendering software and drive it, e.g. via motion capture, to produce a video of the target identity that can respond to challenges.

E.2.5.1 Identification Phase

- Select and configure a 3D rendering and animation pipeline capable of producing a riggable head, e.g. a parametric 3D face model or an avatar system.
- Set up an animation source, e.g. motion capture, to drive head pose, gaze and expression, and prepare scripts to render and deliver the result as IAI with the expected resolution, frame rate and pixel format, in real time where the TOE requires interaction.
- Evaluate render quality with different target identities: biometric similarity to genuine target images, presence of rendering artifacts, behavior in relevant challenge-response settings and temporal consistency.

E.2.5.2 Exploitation Phase

- Obtain images of the target identity, e.g. from ID document.
- Reconstruct or fit a 3D head of the target identity and texture it from the obtained material.
- Drive the rendered head with motion capture or a scripted animation according to the challenge of the TOE.
- Inject the rendered stream or video using the established injection method.

E.2.5.3 Optimization Aspects

- Apply post-processing (face enhancement, color correction) to improve visual quality. Refer to ►Section E.5.
- Obtain multiple views of the targeted identity to render models with higher fidelity meshes and textures.
- Use identities that are more simple to render (e.g. avoid complex hair structures), except if the reaction of the system on obviously rendered material wants to be tested.

E.2.5.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< three days	4
Expertise	Proficient	2	Proficient	2
Total Weight			5 + 6 = 11	
Min. Attack Level			Basic	
Applicability				
IAI real-time capability	Pre-rendered and Real-time (pipeline-dependent)			

Table E.7 Attack rating and applicability for 3D rendered faces

E.2.6 Fully Generated Faces

Generate a video of a fully synthetic face using generative AI. The face does not correspond to a genuine reference of a real person, so this instrument targets TOE that can be attacked with a synthetic identity, typically together with a correspondingly fabricated ID document (see ►Section E.3.5). Where the TOE verifies the

identity against an authoritative reference, e.g. a chip-verified document portrait or an authoritative register, and this verification cannot be reproduced through the established IAM, the instrument is not applicable.

E.2.6.1 Identification Phase

- Select and configure a generative pipeline capable of producing a photorealistic video of a synthetic face.
- Evaluate the generated identities for face image quality, temporal consistency and behavior in relevant challenge-response settings. Determine if the pipeline can be optimized for real-time use-cases.

E.2.6.2 Exploitation Phase

- Generate a synthetic face and produce the response video for the presented challenges.
- Where the TOE authenticates an ID document through the video stream, pair the synthetic face with a correspondingly generated document (see ▶Section E.3.5). The crafting of physical fraudulent documents is out of scope of this document.
- Inject the stream or video using the established injection method.

E.2.6.3 Optimization Aspects

- Apply post-processing (face enhancement, color correction) to improve realism. Refer to ▶Section E.5.
- Refer to ▶Section E.5.4 for temporal optimizations.
- Combine with adversarial perturbations to evade deepfake detection systems.

E.2.6.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Layperson	0	Layperson	0
Total Weight		1 + 0 = 1		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.8 Attack rating and applicability for fully generated faces

E.3 ID Document / Security Feature Synthesis

The instruments in this section target the document authentication of the TOE when the ID document is presented and verified through the video stream. They are not relevant where the document is authenticated cryptographically, e.g. by reading the chip via NFC with passive and active authentication or by comparison against an authoritative register, and this verification cannot be reproduced through the established IAM (see ▶EVA-MTC-14). The crafting of physical fraudulent documents is out of scope of this document, refer to ▶EG BSI ID-Docs. The common assumptions of ▶Table C.2 apply, where access to the document image is treated analogously to the access to biometric characteristics. The ratings below cover the base pipeline only. Simulating security features, handling document liveness or tilt challenges and matching camera characteristics are optimization aspects that add to the rating depending on the TOE (see ▶Appendix C).

E.3.1 Full ID Document Projection

Render a complete image of the target ID document and composite it onto a physical carrier card presented in the video, applying a per-frame perspective transform so it matches the card's position and presented angle. Where the ID document type carries security features, render and overlay them per-frame as described in ▶Section E.3.2.

E.3.1.1 Identification Phase

- Obtain or reconstruct the template of the target ID document type: layout, fonts, background print, attribute positions, portrait position and the machine readable zone format according to ►ICAO Doc 9303 Part 3. If non-public fonts are used on the document, attempt to reconstruct the font from multiple document scans.
- Build a renderer that populates the template with chosen identity data and a portrait and produces correct check digits for the machine readable zone.
- Set up a pipeline that tracks the carrier card in the live video, e.g. by detecting ArUco markers at known positions on the carrier card, and composite the rendered document over the markers so they are not visible to the TOE. Warp the rendered document onto the card with a per-frame homography before feeding it to the established IAM.

E.3.1.2 Exploitation Phase

- Collect the identity data and a portrait of the target identity.
- Populate the template and render the document image.
- Present a blank or generic carrier card to the camera and run the compositing pipeline in real time, or pre-render the video for a fixed presentation.
- Inject the stream or the video using the established injection method.

E.3.1.3 Optimization Aspects

- Match camera characteristics such as resolution, blur, noise and color to the genuine capture. Refer to ►Section E.5.
- Drive the perspective transform from the tracked card pose to handle document specific challenge-response tasks, e.g. tilting or rotating the document.
- Instead of a blank carrier, present a genuine document of an accepted type and composite the rendered image over it at reduced opacity, so its genuine security features show through. This can defeat a TOE that only checks whether a security feature is present, even though the whole visible document is rendered.

E.3.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< one day	1
Expertise	Proficient	2	Layperson	0
Total Weight		5 + 1 = 6		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (pipeline-dependent)			

Table E.9 Attack rating and applicability for full document projection

E.3.2 Security Feature Projection

Composite only the security features, e.g. holograms or optically variable ink, onto a carrier card presented in the video, applying a per-frame perspective transform and a view-dependent appearance model while relying on the physical card for the remaining appearance.

E.3.2.1 Identification Phase

- Capture the appearance of the security features from a genuine document of the target ID document type, to render them image-based. Record the document under many view and illumination directions, e.g. by fixing the document and camera while moving a light source and logging its direction per frame, or by moving a mobile camera with its light active over a fixed document while recording fiducial markers (ArUco)

to recover the relative pose per frame. This path requires temporary access to a genuine document of the target identity.

- Alternatively, author the features synthetically and render them with a 3D rendering pipeline, without needing a genuine document. Model the geometry and the angle and wavelength dependent optical response of each feature, e.g. the diffraction behavior of a hologram.
- Build a renderer that produces the feature appearance for the tracked card pose. For the captured appearance, index it as a bidirectional texture function (BTF) and interpolate between the nearest samples. For the authored model, evaluate it per frame depending on the presented angle of the tracked card.
- Set up a pipeline that tracks the card in the live video and composites the rendered features at their correct positions before feeding the result to the established IAM.

E.3.2.2 Exploitation Phase

- Prepare (e.g. following ▶Section E.3.1) a carrier card that carries the static printed appearance of the document for the target identity but lacks the genuine security features, and present it to the camera.
- Run the compositing pipeline in real time so the features react to the presented angle, or pre-render the video for a fixed presentation.
- Inject the stream or the video using the established injection method.

E.3.2.3 Optimization Aspects

- Sample enough view and illumination directions that the feature reacts plausibly across the full range of presented angles the TOE requests. A single slice, e.g. a fixed view or a camera-colocated light, only matches illumination close to what was sampled.
- Where easily possible, mimic security features physically and only render the security features that are hard to recreate, e.g. print the static template on a polycarbonate card so the general reflectance does not need to be simulated.
- Match camera characteristics and local lighting so the composited features blend with the genuine card. Refer to ▶Section E.5.

E.3.2.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 25 days	6	< one day	1
Expertise	Expert	5	Layperson	0
Total Weight		11 + 1 = 12		
Min. Attack Level		Basic		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (pipeline-dependent)			

Table E.10 Attack rating and applicability for security feature projection

E.3.3 Partial Document Projection

Composite only a segmented region of a presented ID document, e.g. the facial portrait or a printed identity attribute, applying a per-frame perspective transform that matches the presented angle while relying on the card for the remaining appearance. The region can be composited in two modes. In opaque mode it is replaced outright, which overwrites any genuine security feature overlapping it. In transparent mode, over a presented genuine document, it is blended at reduced opacity so a genuine security feature overlapping the region shows through and keeps its authentic appearance, similar to a morph of the two documents. The transparent mode can be for example relevant where the TOE verifies a security feature that can overlap the manipulated region, because the genuine feature still reads as authentic while the visible identity is faked.

E.3.3.1 Identification Phase

- Set up segmentation and tracking of the region of interest in the live video of the presented document, e.g. by matching keypoints against a reference image of the document to recover the per-frame homography.
- For the facial portrait, configure a face manipulation instrument, e.g. according to ▶Section 3.6.2, to generate the replacement region.
- Build a pipeline that warps the edited region onto the tracked document with a per-frame homography and either replaces it opaquely or blends it at reduced opacity into the surrounding genuine print.

E.3.3.2 Exploitation Phase

- Collect a portrait of the target identity, or prepare the edited identity attributes, for the region to be manipulated.
- Present a document of the target ID document type to the camera. For the transparent mode, present a genuine document so its security features show through.
- Composite the prepared portrait or attributes onto the segmented region, opaquely or at reduced opacity, in real time, or pre-render the video.
- Inject the stream or the video using the established injection method.

E.3.3.3 Optimization Aspects

- Match the color, sharpness and grain of the edited region to the surrounding genuine print so the boundary is not visible. Refer to ▶Section E.5.
- In transparent mode, tune the overlay opacity so the genuine attributes underneath are sufficiently masked while the overlapping security feature still reads as authentic. Too high an opacity hides the genuine feature, too low leaves the genuine data showing through as a ghost image.
- Once the document is localized, switch to a lightweight object tracker to reduce the processing time per frame and keep up in real time.
- For the facial region, apply the optimization aspects of the chosen face manipulation instrument, e.g. ▶Section E.2.1 or ▶Section E.2.2.
- Keep the printed data and the machine readable zone consistent when an identity attribute is edited.

E.3.3.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one day	1
Expertise	Proficient	2	Layperson	0
Total Weight		4 + 1 = 5		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (pipeline-dependent)			

Table E.11 Attack rating and applicability for partial document projection

E.3.4 Copy-Move of Segmented Areas

Record two ID documents simultaneously under matched conditions, copy segmented areas from the source document onto the target ID document and present only the crop of the composited target ID document.

E.3.4.1 Identification Phase

- Set up a capture environment that records two documents under similar angle, distance and lighting with respect to the light source and the recording device.

- Set up segmentation and copy-move of the region of interest from the source document onto the target ID document, with blending at the boundary.
- Set up a pipeline that presents only the crop of the composited target ID document to the established IAM.

E.3.4.2 Exploitation Phase

- Obtain a source document carrying the desired region, e.g. a portrait, and a target ID document of the target ID document type accepted by the TOE.
- Record both documents under matched conditions and perform the copy-move.
- Inject the cropped stream or video using the established injection method.

E.3.4.3 Optimization Aspects

- Refine the matching of capture conditions so the transplanted region shares the same lighting, perspective and noise as the target ID document.
- Blend the boundary and match local color and grain so the transplant is not visible. Refer to ►Section E.5.

E.3.4.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one day	1
Expertise	Proficient	2	Layperson	0
Access to biometric characteristics	Moderate	4	Moderate	4
Total Weight		8 + 5 = 13		
Min. Attack Level		Basic		
Applicability				
IAI real-time capability	Pre-rendered			

Table E.12 Attack rating and applicability for copy-move of segmented areas

E.3.5 Fully Generated ID Documents

Generate a video of the target ID document, possibly using a reference image of the target ID document, using generative models.

E.3.5.1 Identification Phase

- Select and configure a generative pipeline capable of producing a document video of the target ID document type, optionally conditioned on a reference image of the document.
- Set up scripts to drive the generation, including motion of the document, and to feed the result into the established IAM.

E.3.5.2 Exploitation Phase

- Provide the target identity data and portrait, and a reference image of the target ID document where required by the model.
- Generate the document video, offline or in real time depending on the model.
- Inject the stream or the video using the established injection method.

E.3.5.3 Optimization Aspects

- Ensure the generated printed data and the machine readable zone are internally consistent, including correct check digits according to ►ICAO Doc 9303 Part 3.
- Match camera characteristics and motion to a plausible genuine capture. Refer to ►Section E.5.

E.3.5.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< 7 days	3	< one hour	0
Expertise	Proficient	2	Layperson	0
Total Weight		5 + 0 = 5		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.13 Attack rating and applicability for fully generated ID documents

E.4 Adversarial Attacks

E.4.1 Digital Adversarial Perturbations

Apply gradient-based adversarial perturbations to IAI output frames to evade detection systems and/or alter face comparison scores.

E.4.1.1 Identification Phase

- Set up surrogate models that approximate the target system's countermeasures, face comparison, or face quality estimation components (e.g. open-source / own presentation attack detection models, deepfake detection models, face recognition models, or face quality estimation models).
- Find good selections of those surrogate models that show the highest transferability to the target model. If the attack should be performed in real-time, each selection needs to be small enough so that the attack can be run in real-time.
- For each surrogate selection, select a gradient-based adversarial attack (e.g. FGSM) and calculate a noise pattern targeting the surrogate models to evade detection and/or alter face comparison scores and/or increase the score of face quality estimation.
- Evaluate the best attack parameterization and surrogate selections against the target model(s).

E.4.1.2 Exploitation Phase

- Apply the adversarial perturbation pipeline to each frame of the IAI output or camera output in real-time or as a pre-calculated video.
- Inject the perturbed stream or the video using the established injection method.

E.4.1.3 Optimization Aspects

- Use varied ensembles of diverse surrogate models to improve transferability to the unknown target system.
- If combined with another IAI (e.g. a face swap) and the attacked model is a defense against this IAI category (e.g. a deepfake detection if the IAI is a face swap), the surrogate models should be able to detect the IAI or be fine-tuned to do so.
- If additional information of the attacked system is available (e.g. network architecture, used public datasets), the surrogate models can be fine-tuned with the dataset or own surrogate models can be trained with a similar architecture for a better approximation of the target system.
- Constrain perturbation magnitude (L-infinity norm) to remain less perceptible and avoid triggering quality-based rejection.
- Combine with multiple target models (e.g. deepfake detection and face comparison) to simultaneously address identity matching, detection evasion, and quality estimation.

E.4.1.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	> 25 days	10	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		15 + 0 = 15		
Min. Attack Level		Basic		
Applicability				
IAI real-time capability	Pre-rendered and Real-time			

Table E.14 Attack rating and applicability for digital adversarial perturbations

E.4.2 Trained Universal Pattern Attacks

Train a universal adversarial pattern that can be applied to any input frame to evade detection and/or alter matching scores, without requiring per-image optimization at inference time.

E.4.2.1 Identification Phase

- Set up surrogate models that approximate the target system's countermeasures, face comparison, or face quality estimation components (e.g. open-source / own presentation attack detection models, deepfake detection models, face recognition models, or face quality estimation models).
- Find good selections of those surrogate models that show the highest transferability to the target model.
- For each surrogate selection, train a universal adversarial pattern targeting the surrogate models to evade detection and/or alter face comparison scores and/or increase the score of face quality estimation.
- Evaluate the best attack parameterization and surrogate selections against the target model(s).

E.4.2.2 Exploitation Phase

- Apply the universal pattern to each frame of the IAI output or camera output in real-time.
- Inject the perturbed stream or the video using the established injection method.

E.4.2.3 Optimization Aspects

- Use varied ensembles of diverse surrogate models to improve transferability to the unknown target system.
- If combined with another IAI (e.g. a face swap) and the attacked model is a defense against this IAI category (e.g. a deepfake detection if the IAI is a face swap), the surrogate models should be able to detect the IAI or be fine-tuned to do so.
- If additional information of the attacked system is available (e.g. network architecture, used public datasets), the surrogate models can be fine-tuned with the dataset or own surrogate models can be trained with a similar architecture for a better approximation of the target system.
- Constrain perturbation magnitude (L-infinity norm) or add a loss (e.g. sharpness-loss) to the training pipeline of the universal pattern to remain less perceptible and avoid triggering quality-based rejection.
- Combine with multiple target models (e.g. deepfake detection and face comparison) to simultaneously address identity matching, detection evasion, and quality estimation.

E.4.2.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	> 25 days	10	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		15 + 0 = 15		
Min. Attack Level		Basic		

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Applicability				
IAI real-time capability	Real-time			

Table E.15 Attack rating and applicability for trained universal pattern attacks

E.4.3 Trained Adversarial Generator Network

Train an adversarial image-to-image generator network (e.g. an AdvGAN-variation) to transform input frames to evade detection and/or alter comparison scores.

E.4.3.1 Identification Phase

- Set up surrogate models that approximate the target system's countermeasures, face comparison, or face quality estimation components (e.g. open-source / own presentation attack detection models, deepfake detection models, face recognition models, or face quality estimation models).
- Find good selections of those surrogate models that show the highest transferability to the target model.
- For each surrogate selection, train an adversarial image-to-image network (e.g. an AdvGAN-variation) targeting the surrogate models to evade detection and/or alter face comparison scores and/or increase the score of face quality estimation.
- Evaluate the best attack parameterization and surrogate selections against the target model(s).

E.4.3.2 Exploitation Phase

- Apply the trained generator network to each frame of the IAI output or camera output in real-time.
- Inject the perturbed stream or the video using the established injection method.

E.4.3.3 Optimization Aspects

- Use varied ensembles of diverse surrogate models to improve transferability to the unknown target system.
- If combined with another IAI (e.g. a face swap) and the attacked model is a defense against this IAI category (e.g. a deepfake detection if the IAI is a face swap), the surrogate models should be able to detect the IAI or be fine-tuned to do so.
- If additional information of the attacked system is available (e.g. network architecture, used public datasets), the surrogate models can be fine-tuned with the dataset or own surrogate models can be trained with a similar architecture for a better approximation of the target system.
- Constrain perturbation magnitude (L-infinity norm) or add a loss (e.g. sharpness-loss, increase discriminator weight if a Generative Adversarial Network based model is used) to the training pipeline of the network to remain less perceptible and avoid triggering quality-based rejection.
- Combine with multiple target models (e.g. deepfake detection and face comparison) to simultaneously address identity matching, detection evasion, and quality estimation.

E.4.3.4 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	> 25 days	10	< one hour	0
Expertise	Expert	5	Layperson	0
Total Weight		15 + 0 = 15		
Min. Attack Level		Basic		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.16 Attack rating and applicability for trained adversarial generator network

E.4.4 In Discussion: Query-Based Black-Box Adversarial Attack

This method assumes the attacker can repeatedly query the target system and observe binary pass/fail responses to iteratively refine adversarial examples.

E.4.4.1 Feasibility Considerations

- Requires a large number of queries (typically thousands) to the target system, which may be rate-limited or session-bound in identity proofing contexts.
- Each query in a remote identity proofing system typically involves a full authentication session, making the practical query budget very limited.
- Session-specific challenges (random head movements, spoken phrases) further reduce the feasibility of iterative query-based approaches, as each session context differs.
- May be more feasible if the detection system exposes a score or confidence value rather than only a binary decision, but this is uncommon in production systems.

E.4.5 In Discussion: Query-Based Model Stealing

This method assumes the attacker can query the target system sufficiently to train a surrogate model that closely approximates the target's decision boundaries.

E.4.5.1 Feasibility Considerations

- Requires very large query volumes (tens of thousands or more) to build an accurate surrogate, which is impractical for session-based identity proofing systems.
- If partially feasible, the stolen surrogate model could improve transferability of adversarial attacks compared to using unrelated open-source surrogate models.

E.5 Post-Processing of Manipulations

Post-processing techniques are applied to IAI output to improve visual quality, mask artifacts, and evade detection mechanisms. These are typically combined with face manipulation instruments rather than used standalone.

E.5.1 Face Enhancement & Restoration

E.5.1.1 Techniques

- Apply face restoration models to improve face quality, sharpen details, and remove compression or generation artifacts.
- Use super-resolution models to upscale low-resolution face swaps or animations to match the expected camera resolution.
- Correct specific facial features separately if they are relevant to the TOE, like eye gaze direction or the mouth interior.
- Transfer skin texture detail (pores, wrinkles) from real face images onto overly smooth synthetic faces to evade detectors that flag lack of skin texture.

E.5.1.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Layperson	0	Layperson	0
Total Weight		1 + 0 = 1		
Min. Attack Level		No rating		
Applicability				

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.17 Attack rating and applicability for face enhancement and restoration

E.5.2 Lighting & Color Correction

E.5.2.1 Techniques

- Match color temperature, white balance, and gamma curve of a synthetic face to the background and environment visible in the video.
- Add realistic specular highlights if they are relevant to the TOE, e.g. if the application turns on a flashlight during the process.

E.5.2.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Proficient	2	Proficient	2
Total Weight		3 + 2 = 5		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.18 Attack rating and applicability for lighting and color correction

E.5.3 Quality Degradation (Artifact Masking)

E.5.3.1 Techniques

- Apply degradation to raw decoded frames before the final encoding step to mask high-frequency artifacts from face synthesis or boundary blending. Avoid recompressing already-compressed streams to prevent detectable double compression artifacts. If recompression is unavoidable, applying noise before compression can help mask quantization artifacts from prior encoding passes.
- Add realistic camera noise (sensor noise, ISO noise) matching the target device's camera characteristics.
- Apply slight Gaussian blur to face boundaries to reduce visible seams between swapped and original regions.

E.5.3.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Proficient	2
Total Weight		4 + 2 = 6		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.19 Attack rating and applicability for quality degradation

E.5.4 Temporal Manipulations

E.5.4.1 Techniques

- Apply temporal smoothing across consecutive frames to reduce flicker and jitter in generated faces.

- In scenarios where parts of the frames are replaced, e.g. face swapping, ensure consistent boundary positioning across frames to avoid temporal jittering in the swapping areas.
- Use frame interpolation to reach the target frame rate expected by the application (e.g. a constant 30 FPS) if the IAI output has a lower or inconsistent frame rate. Add independent per-frame noise after interpolation, to avoid detection of blending noise patterns.
- If a TOE requires real-time streaming, but the IAI method can only generate full videos (e.g. video reenactment or adversarial attacks that are not real-time capable), a delay-based approach can be attempted in addition to testing with prepared videos. First, stream a default pose video showing a person sitting idle in front of the camera. When a challenge is requested, generate the IAI and switch to streaming the generated video once it is ready. Afterwards, resume streaming the idle video.

E.5.4.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Proficient	2	Proficient	2
Total Weight		4 + 2 = 6		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.20 Attack rating and applicability for temporal manipulations

E.5.5 Variation of Distance

Vary the apparent size of the object of interest, e.g. a face or an ID document, by changing its distance to the camera. This probes how the TOE reacts to different object scales and determines the scale at which the IAI is processed most favorably.

E.5.5.1 Techniques

- Present or render the object of interest at varying distances from the camera to change the resolution of the region of interest seen by the TOE.
- Determine the scale at which the IAI achieves the best trade-off between biometric quality and artifact visibility, e.g. a smaller face region can hide synthesis artifacts while still passing the quality thresholds.

E.5.5.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Layperson	0	Layperson	0
Total Weight		1 + 0 = 1		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time			

Table E.21 Attack rating and applicability for variation of distance

E.5.6 Variation of Background

Use varied backgrounds behind the object of interest, e.g. a plain uniform or a more complex background. This probes how the TOE reacts to the surrounding scene and can reduce cues that reveal an injected or synthetic presentation.

E.5.6.1 Techniques

- Vary the background behind the presented or rendered object of interest, e.g. a plain uniform background or a more complex scene.
- Use a background that masks boundary or compositing artifacts, e.g. around a swapped face or a composited document.

E.5.6.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< one day	1	< one hour	0
Expertise	Layperson	0	Layperson	0
Total Weight		1 + 0 = 1		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time			

Table E.22 Attack rating and applicability for variation of background

E.5.7 Sensor Noise Synthesis

Injection detectors may look for the noise signature that a genuine camera leaves on every frame, in particular the photo-response non-uniformity (PRNU) that acts as a sensor fingerprint, together with read noise, fixed-pattern noise and demosaicing traces. Synthetic content often lacks this signature, carries an inconsistent one across the sequence, or shows the signature of the wrong sensor. In contrast to a quality degradation, which adds noise to mask synthesis artifacts, the goal here is therefore to satisfy sensor-fingerprint and noise-consistency analysis.

E.5.7.1 Techniques

- Model the noise of a real sensor rather than adding generic Gaussian noise: combine a fixed PRNU pattern with signal-dependent photon (shot) noise, read noise and quantization, applied after demosaicing so the result matches a real capture pipeline.
- Keep the PRNU pattern constant across all frames of the session while letting the signal-dependent components vary per frame, so the fingerprint stays temporally consistent as expected from a single physical sensor.
- Where the TOE is suspected to compare the stream against a claimed or enrolled device, estimate the PRNU of that device from reference material (e.g. several flat or uniform images from the same camera) and reproduce it instead of an arbitrary pattern.
- Match the noise level to the exposure and ISO implied by the rest of the frame, and apply it before the final encoding so it is shaped by the same compression as a genuine capture.

E.5.7.2 Minimal Attack Rating

Criteria	Identification Interval	Id. Weight	Exploitation Interval	Exp. Weight
Time Effort	< three days	2	< one hour	0
Expertise	Expert	5	Proficient	2
Total Weight		7 + 2 = 9		
Min. Attack Level		No rating		
Applicability				
IAI real-time capability	Pre-rendered and Real-time (model-dependent)			

Table E.23 Attack rating and applicability for sensor noise synthesis

List of Abbreviations

Abbreviation	Description
IA	injection attack
IAD	injection attack detection
IAI	injection attack instrument
IAM	injection attack method
LoA	level of assurance
RIDP	remote identity proofing
TOE	target of evaluation

Bibliographie

- [BSI TR-03107] *Technische Richtlinie TR-03107. Elektronische Identitäten und Vertrauensdienste im E-Government*. BSI.
Version 1.1.1
07.05.2019.
- [BSI TR-03147] *Technische Richtlinie TR-03147. Vertrauensniveaubewertung von Verfahren zur Identitätsprüfung natürlicher Personen*. BSI.
Version 1.0.1
28.12.2021.
- [BSI TR-03166] *Technische Richtlinie TR-03166. Technical Guideline for Biometric Authentication Systems*. BSI.
Version 2.0
26.01.2026.
- [Carta et al., 2024] *An Overview of Biometric Data Injection Attacks on Remote Identity Proofing Solutions*. Carta Kevin, Huynh André, Mouille Stéphane and El Mrabet Nadia. 2024.
- [CEN/TS 18099] *CEN/TS 18099:2025. Biometric data injection attack detection*. CEN. 2025.
- [CEN/TS 18212] *CEN/TS 18212-5. Personal Identification - Requirements for biometric products - Part 5: Face biometrics*. CEN. 2026.
- [EG BSI ID-Docs] *Evaluation Guidance for Remote Identity Proofing. Part 03: ID documents*. BSI.
Version x.0
in development.
- [EG BSI TR-03166] *Evaluation Guidance BSI TR-03166. Evaluation Guidance for the BSI TR-03166*. BSI.
Version 2.0
26.01.2026.
- [ETSI/ESI TS 119 461] *Policy and security requirements for trust service components providing identity proofing of trust service subjects*. ETSI/ESI.
Version 2.1.1
2025-02.
- [ICAO Doc 9303 Part 3] *ICAO Doc 9303. Part 3: Specifications Common to all Machine Readable Travel Documents*. International Civil Aviation Organization.
Eighth Edition
2021. https://www.icao.int/sites/default/files/publications/DocSeries/9303_p3_cons_en.pdf.
- [ISO/IEC 25456] *ISO/IEC 25456 (in development). Biometric data injection attack detection*. ISO. estimated for 2027 / 2028.